

BAN CƠ YẾU CHÍNH PHỦ
HỌC VIỆN KỸ THUẬT MẬT MÃ



BÁO CÁO THỰC TẬP DỰ ÁN CÔNG NGHỆ

XÂY DỰNG MÔ HÌNH SOC
(SỬ DỤNG WAZUH VÀ SNORT)

Ngành: An toàn thông tin

Mã số: 7.48.02.02

Sinh viên thực hiện:

Vũ Văn Thắng – AT20N0147

Võ Lê Chí Bảo – AT20N0105

Lều Thanh Tùng – AT20N0145

Nguyễn Đức Mạnh – AT20N0129

Nguyễn Thanh Hòa – AT20N0121

Giảng viên hướng dẫn:

Th.s Nguyễn Anh Khôi

TP. Hồ Chí Minh – 2026

LỜI CẢM ƠN

Nhóm chúng em xin chân thành cảm ơn Ban Giám hiệu cùng quý thầy cô Khoa An toàn thông tin - Học viện Kỹ thuật Mật mã đã tận tình giảng dạy và tạo điều kiện thuận lợi cho chúng em trong suốt quá trình học tập và thực hiện đề tài.

Đặc biệt, nhóm xin gửi lời cảm ơn sâu sắc đến **Th.S Nguyễn Anh Khôi** đã tận tình hướng dẫn, hỗ trợ và đóng góp nhiều ý kiến quý báu để nhóm có thể hoàn thành đề tài “*Xây dựng mô hình SOC sử dụng Wazuh và Snort*”.

Bên cạnh đó, chúng em cũng xin cảm ơn gia đình và bạn bè đã luôn động viên, hỗ trợ tinh thần trong suốt quá trình thực hiện đồ án.

Do còn hạn chế về thời gian và kinh nghiệm thực tế nên báo cáo khó tránh khỏi những thiếu sót. Nhóm rất mong nhận được sự góp ý từ quý thầy cô để đề tài được hoàn thiện hơn.

Nhóm chúng em xin chân thành cảm ơn!

Mục lục

Lời cảm ơn	i
Danh mục từ viết tắt	v
Danh sách hình vẽ	viii
Danh sách bảng	ix
Lời mở đầu	x
1 Tổng quan về đề tài và xu hướng	1
1.1 Lý do chọn đề tài	1
1.2 Tổng quan về Trung tâm điều hành an ninh mạng (SOC)	2
1.2.1 Khái niệm SOC	2
1.2.2 Ba trụ cột cốt lõi của SOC	2
1.3 Mục tiêu và phạm vi nghiên cứu	3
1.3.1 Mục tiêu nghiên cứu:	3
1.3.2 Phạm vi nghiên cứu:	3
1.4 Tổng quan các công nghệ cốt lõi	3
1.4.1 Hệ thống Proxy trung gian và kiểm soát định danh	4
1.4.2 Hệ thống SIEM Wazuh	4
1.4.3 Hệ thống phát hiện xâm nhập mạng (Snort)	4
2 Thiết kế và Triển khai hệ thống	5
2.1 Kiến trúc tổng thể của hệ thống	5
2.1.1 Sơ đồ tổng thể	5
2.1.2 Nguyên tắc thiết kế	5
2.1.3 Môi trường và Hạ tầng triển khai	7
2.1.4 Phân đoạn mạng và Chính sách kiểm soát	9
2.2 Luồng truy cập và phân phối dịch vụ	10
2.2.1 Luồng Quản trị viên (Identity-Aware Proxy)	10
2.2.2 Luồng Khách thuê (Remote Access Workspace)	11

2.2.3	Luồng Người dùng cuối (Public Web Access)	12
2.3	Triển khai Cấu hình Chi tiết	13
2.3.1	Triển khai tường lửa và định tuyến	13
2.3.2	Triển khai lớp xác thực IAP (Nginx & Authelia)	14
2.3.3	Triển khai dịch vụ lỗi (Guacamole, Tomcat 9 & MariaDB)	16
2.3.4	Triển khai giám sát tập trung	17
2.4	Tối ưu hóa và Khắc phục sự cố trong quá trình triển khai	18
2.4.1	Khắc phục bất đồng bộ định dạng Log giữa Snort và Wazuh	18
2.4.2	Xử lý lỗi mất dịch vụ WebGUI trên pfSense	19
2.4.3	Xử lý máy chủ Wazuh sập nguồn/treo hệ thống do quá tải	19
2.4.4	Nghẽn cổ chai băng thông (Network Bottleneck) trên pfSense	19
2.5	Kết luận chương	20
3	Thực nghiệm	21
3.1	Phương pháp thực nghiệm	21
3.2	Kịch bản 1: Aggressive enumeration scan	21
3.2.1	Mục tiêu	21
3.2.2	Tiến hành thực nghiệm:	22
3.2.3	Kết quả thực nghiệm	22
3.3	Kịch bản 2: Evasive stealth scan	24
3.3.1	Mục tiêu	24
3.3.2	Tiến hành thực nghiệm	24
3.3.3	Kết quả thực nghiệm	25
3.3.4	Đánh giá kết quả	26
3.4	Kịch bản 3: Tấn công dò mật khẩu (Brute-force) và Phản ứng tự động	26
3.4.1	Mục tiêu	26
3.4.2	Tiến hành thực nghiệm	27
3.4.3	Kết quả thực nghiệm	27
3.4.4	Đánh giá kết quả	29
3.5	Kịch bản 4: Giám sát toàn vẹn tệp tin (FIM) tại điểm cuối	29
3.5.1	Mục tiêu	29
3.5.2	Tiến hành thực nghiệm	30
3.5.3	Kết quả thực nghiệm	30
3.5.4	Đánh giá kết quả	31
3.6	Kết luận chương 3	31
	Kết luận	32

Hướng phát triển	34
Tài liệu tham khảo	36
A Cấu hình rules firewall	38
B Bộ giải mã tùy chỉnh (Custom Decoder) cho pfSense trên Wazuh	39
C Script Systemd Service cho Tomcat 9 trên Debian 12	40

Danh mục từ viết tắt

SOC	Security Operations Center
PPT	People, Process, Technology
SIEM	Security Information and Event Management
NIDS	Network Intrusion Detection System
HIDS	Host-based Intrusion Detection System
IDS	Intrusion Detection System
IPS	Intrusion Prevention System
IAP	Identity-Aware Proxy
MFA	Multi-Factor Authentication
VPN	Virtual Private Network
VLAN	Virtual Local Area Network
DMZ	Demilitarized Zone
NAT	Network Address Translation
WAN	Wide Area Network
LAN	Local Area Network
SSH	Secure Shell
RDP	Remote Desktop Protocol
VNC	Virtual Network Computing
HTTP	HyperText Transfer Protocol
HTTPS	HyperText Transfer Protocol Secure

TCP	Transmission Control Protocol
UDP	User Datagram Protocol
IP	Internet Protocol
SSL	Secure Sockets Layer
OTP	One-Time Password
RBAC	Role-Based Access Control
API	Application Programming Interface
GUI	Graphical User Interface
SQL	Structured Query Language
JDBC	Java Database Connectivity
MSSQL	Microsoft SQL Server
Syslog	System Logging Protocol
Regex	Regular Expression
JSON	JavaScript Object Notation
FIM	File Integrity Monitoring
MITRE	MITRE ATT&CK Framework
EICAR	European Institute for Computer Antivirus Research
MD5	Message Digest Algorithm 5
SHA-1	Secure Hash Algorithm 1
SHA-256	Secure Hash Algorithm 256
VPS	Virtual Private Server
ISP	Internet Service Provider
URL	Uniform Resource Locator
CPU	Central Processing Unit

RAM	Random Access Memory
PHP	Hypertext Preprocessor
OS	Operating System

Danh sách hình vẽ

2.1	Sơ đồ tách biệt mặt phẳng	7
2.2	Sơ đồ cấu trúc liên kết mạng vật lý và môi trường ảo hóa	8
2.3	Luồng hoạt động của quản trị viên	11
2.4	Luồng hoạt động của khách thuê	12
2.5	Luồng hoạt động của người dùng cuối	13
3.1	Nmap Aggressive enumeration scan	22
3.2	Snort phát hiện Nmap Scripting Engine (Level 8)	23
3.3	Snort phát hiện hành vi scan port database, VNC, OS Detection . . .	23
3.4	Wazuh phân tích log và tăng Rule level từ 5 lên 10	24
3.5	Evasive stealth scan từ máy tấn công	25
3.6	Hiện tượng nhiễu loạn cảnh báo do kỹ thuật IP Spoofing tạo ra . . .	26
3.7	Brute-force vào API xác thực của Authelia	27
3.8	Wazuh xử lý cảnh báo Brute-force và tự động kích hoạt chặn IP . . .	28
3.9	Wazuh block thiết bị kẻ tấn công	29
3.10	Thực thi hành vi thả tệp tin giả lập mã độc EICAR vào máy chủ Web	30
3.11	Wazuh ghi nhận sự kiện FIM và phát cảnh báo tệp tin EICAR	30

Danh sách bảng

2.1	Quy hoạch VLAN	9
2.2	Cấu hình định tuyến Nginx Reverse Proxy	15
2.3	Các nguồn chính cần giám sát tập trung	18
3.1	So sánh kết quả phát hiện theo loại rà quét	22
A.1	Tổng hợp Firewall Rules trên pfSense	38

Lời mở đầu

Hiện nay, trong kỷ nguyên an ninh mạng thích ứng (*The Era of Adaptive Cybersecurity*), các mối đe dọa trực tiếp đến an toàn thông tin có sự gia tăng mạnh mẽ về mức độ và phạm vi ảnh hưởng. Dữ liệu từ vật lý (tập trung) đến phân tán (số hóa), từ tĩnh (lưu trữ) sang động (luân chuyển/học tập) và từ mục tiêu bị đánh cắp đến vũ khí được cá nhân/tổ chức hóa. Với phạm vi tấn công chuyển đổi cao như trên, SOC (*Security Operations Center*) chuyển từ vị trí hỗ trợ công nghệ thông tin trở thành hạt nhân điều hành của toàn bộ hệ sinh thái giám sát an ninh.

Báo cáo này trình bày quá trình tập trung thiết kế và triển khai một mô hình SOC đa lớp quy mô nhỏ. Mô hình có sự chuyển dịch từ giám sát tập trung (*Centralized Monitoring*) sang giám sát đa tầng (*Layered System Monitoring*), kết hợp nền tảng giám sát máy chủ **Wazuh** với hệ thống phát hiện xâm nhập mạng **Snort** nhằm đồng bộ hóa dữ liệu giám sát từ các tầng. Được triển khai trên môi trường ảo hóa (Homelab) với Wazuh có vị trí trung tâm đóng vai trò thu thập, phân tích và hiển thị cảnh báo và Snort đảm nhiệm chức năng giám sát và phát hiện sự bất thường trên lưu lượng mạng.

Trong quá trình thực nghiệm, việc triển khai các kịch bản tấn công phổ biến như rà soát các cổng mạng, tấn công dò quét (*Brute-force Attack*),... để đánh giá khả năng giám sát của hệ thống đã được nhóm mô phỏng. Kết quả đạt được từ việc giám sát ở cấp độ gói tin từ Snort và các biến động cụ thể trong các tiến trình hệ thống được Wazuh cung cấp đã cho hệ thống sự giám sát và tổng hợp kịch bản tấn công toàn diện. Từ đó chứng minh tính khả thi của việc triển khai mô hình trên ở quy mô nhỏ phục vụ mục đích giám sát và nghiên cứu an toàn thông tin.

Chương 1

Tổng quan về đề tài và xu hướng

1.1 Lý do chọn đề tài

Trong bối cảnh điện toán đám mây phát triển mạnh mẽ, các mối đe dọa an toàn thông tin đang gia tăng nhanh chóng về cả quy mô lẫn mức độ tinh vi. Các cuộc tấn công ngày càng được tự động hóa, diễn ra liên tục và nhắm vào đa dạng các mục tiêu trên Internet. Các hệ thống mạng, đặc biệt là máy chủ Cloud và VPS, thường xuyên phải hứng chịu những rủi ro như quét cổng mạng (Port Scanning), Brute-force,... vào các dịch vụ quản trị từ xa, và khai thác các lỗ hổng ứng dụng web

Điều này dẫn tới những hậu quả vô cùng nghiêm trọng như là gây gián đoạn dịch vụ, thất thoát dữ liệu nhạy cảm và làm suy giảm uy tín của tổ chức. Trong đó, nhiều báo cáo điều tra từ các cơ quan chức năng đối với những sự kiện rò rỉ dữ liệu lớn đều chỉ ra một nguyên nhân cốt lõi: sự vắng bóng hoặc thất bại của hệ thống giám sát tập trung và cảnh báo chủ động. Điển hình có thể kể đến các sự kiện sau:

- **Sự kiện TalkTalk (Vương quốc Anh, 2015):** TalkTalk đã bị tin tặc tấn công bằng kỹ thuật SQL Injection cơ bản. Văn phòng Ủy viên Thông tin (UK ICO) kết luận nguyên nhân cốt lõi là do TalkTalk đã thất bại trong việc triển khai "*các hoạt động giám sát chủ động*" để phát hiện lỗ hổng kịp thời **ico_talktalk**
- **Thảm họa Cơ quan Quản lý Nhân sự Mỹ - OPM (2014-2015):** Kẻ tấn công đã lẩn trốn trong hệ thống gần một năm để đánh cắp hồ sơ của 22 triệu nhân viên. Báo cáo điều tra đã chỉ trích OPM thiếu "*giám sát liên tục*" và hoàn toàn mù lòa do không nâng cấp các công cụ "*quản lý log*" **opm_breach**
- **Vụ rò rỉ dữ liệu Equifax (Mỹ, 2017):** Dữ liệu của hơn 147 triệu khách hàng bị đánh cắp. Báo cáo điều tra xác định thiết bị giám sát lưu lượng mạng của Equifax đã ngừng hoạt động trong suốt 19 tháng **equifax_breach** do quên gia hạn chứng chỉ, khiến hệ thống phòng thủ hoàn toàn bị vô hiệu hóa

Từ những bài học trên đã cho chúng ta thấy việc giám sát liên tục, phát hiện và ứng phó các mối đe dọa là rất quan trọng. Xuất phát từ nhu cầu thực tiễn đó,

nhóm quyết định thực hiện đề án với đề tài "**Xây dựng mô hình SOC sử dụng Wazuh và Snort**"

1.2 Tổng quan về Trung tâm điều hành an ninh mạng (SOC)

1.2.1 Khái niệm SOC

Trung tâm điều hành an ninh mạng (Security Operations Center - SOC) là một đơn vị tập trung trong tổ chức, chịu trách nhiệm liên tục giám sát, đánh giá và bảo vệ hệ thống công nghệ thông tin (bao gồm mạng, máy chủ, thiết bị đầu cuối và cơ sở dữ liệu) trước các mối đe dọa an ninh mạng. Mục tiêu tối thượng của SOC là phát hiện, phân tích và phản ứng với các sự cố an ninh mạng trong thời gian thực, đảm bảo sự gián đoạn đối với hoạt động kinh doanh ở mức thấp nhất

1.2.2 Ba trụ cột cốt lõi của SOC

Một hệ thống SOC hoàn chỉnh không chỉ là việc mua sắm phần cứng hay phần mềm, mà là sự kết hợp hài hòa của ba yếu tố (PPT - People, Process, Technology):

- **Con người (People):** Là đội ngũ chuyên gia phân tích an ninh (SOC Analysts), kỹ sư ứng phó sự cố (Incident Responders) và thợ săn mối đe dọa (Threat Hunters). Họ là những người trực tiếp đọc hiểu cảnh báo, phân tích mức độ nghiêm trọng và ra quyết định xử lý
- **Quy trình (Process):** Các quy chuẩn và kịch bản chuẩn hóa (Playbooks/Runbooks) hướng dẫn đội ngũ SOC phải làm gì khi đối mặt với từng loại tấn công cụ thể. Ví dụ: Quy trình cách ly máy chủ khi nhiễm Ransomware, quy trình báo cáo lỗ hổng.
- **Công nghệ (Technology):** Là hệ sinh thái các công cụ bảo mật hỗ trợ con người thu thập và phân tích dữ liệu. Đây chính là trọng tâm mà đề án này hướng tới. Công nghệ của SOC thường bao gồm các hệ thống phòng thủ bề mặt (Firewall, IPS/IDS) và hạt nhân trung tâm là hệ thống quản lý sự kiện và thông tin bảo mật (SIEM)

1.3 Mục tiêu và phạm vi nghiên cứu

1.3.1 Mục tiêu nghiên cứu:

Bằng việc kết hợp NIDS (ở đây sử dụng Snort), khả năng giám sát, phân tích nhật ký tại các điểm cuối của HIDS (Ở đây là Wazuh Agent) cùng lớp kiểm soát truy cập, đề án hướng tới các mục tiêu:

1. Xây dựng một mô hình hạ tầng mạng an toàn, phân lập và kiểm soát chặt chẽ được các luồng truy cập.
2. Thiết lập hệ thống giám sát tập trung để thu thập dữ liệu và cảnh báo sự cố.
3. Hiện thực hóa các kịch bản tấn công mạng thực tế để đo lường và đánh giá khả năng phát hiện của các công cụ.

1.3.2 Phạm vi nghiên cứu:

Một Trung tâm điều hành an ninh mạng (SOC) trên thực tế là một tổ chức vận hành quy mô lớn, đòi hỏi nguồn lực khổng lồ về yếu tố Con người (đội ngũ chuyên gia trực 24/7) và Quy trình xử lý sự cố phức tạp

Do giới hạn của một đề án kỹ thuật, đề tài không nhắm đến việc xây dựng toàn diện một phòng ban SOC hoàn chỉnh. Thay vào đó, phạm vi nghiên cứu tập trung vào việc xây dựng nền tảng hạ tầng công nghệ để một SOC có thể hoạt động được. Đề án giải quyết bài toán hạ tầng cốt lõi: thiết lập kiến trúc mạng an toàn (chia VLAN, kiểm soát định danh người dùng) để tạo ra môi trường chuẩn, từ đó thu thập nguồn dữ liệu log sạch sẽ làm đầu vào cho hệ thống phân tích trung tâm SIEM (Wazuh) và các cảm biến mạng (Snort). Đây cũng là nền móng để có thể phát triển thêm về *Quy trình* và *Con người* vào vận hành trong tương lai.

1.4 Tổng quan các công nghệ cốt lõi

Phần này sẽ nói tổng quan các thành phần công nghệ cốt lõi cấu thành hệ thống. Trong đó, đề án sử dụng kết hợp các nền tảng công nghệ mã nguồn mở và các mô hình bảo mật tiên tiến hiện nay. Dưới đây là các thành phần cốt lõi được sử dụng trong hệ thống:

1.4.1 Hệ thống Proxy trung gian và kiểm soát định danh

Để bảo vệ các dịch vụ quản trị nội bộ thay vì sử dụng VPN, đề án áp dụng cơ chế kiểm soát truy cập tại tầng ứng dụng với sự kết hợp của hai công cụ:

- **Nginx (Reverse Proxy):** Đóng vai trò là máy chủ trung gian tiếp nhận toàn bộ các yêu cầu truy cập từ bên ngoài. Nginx giúp ẩn giấu kiến trúc thực sự của hệ thống mạng bên trong và điều hướng luồng dữ liệu (traffic) đến đúng các máy chủ dịch vụ tương ứng
- **Authelia:** Là nền tảng mã nguồn mở cung cấp tính năng xác thực đa yếu tố (MFA). Khi tích hợp với Nginx, Authelia đóng vai trò như một "cổng gác" bắt buộc, yêu cầu người dùng phải xác minh danh tính bằng mật khẩu và mã OTP trước khi luồng truy cập được phép đi qua Reverse Proxy để vào vùng quản trị bên trong

1.4.2 Hệ thống SIEM Wazuh

Wazuh là một nền tảng mã nguồn mở miễn phí, kết hợp giữa hai vai trò chính:

- **SIEM (Security Information and Event Management):** Đóng vai trò bộ não trung tâm, chuyên thu thập, phân tích và tương quan dữ liệu nhật ký (log) từ nhiều thiết bị khác nhau trong mạng để phát hiện các dấu hiệu tấn công
- **HIDS (Host-based Intrusion Detection System):** Wazuh cung cấp các phần mềm tác nhân (Agent) cài đặt trực tiếp lên các máy chủ (Endpoint). Agent này có khả năng theo dõi tính toàn vẹn của tệp tin, phân tích log hệ điều hành và tự động thực thi các hành động phản ứng (Active Response) khi có sự cố

1.4.3 Hệ thống phát hiện xâm nhập mạng (Snort)

- **Khái niệm:** Snort là một hệ thống phát hiện xâm nhập mạng (NIDS - Network Intrusion Detection System) mã nguồn mở nổi tiếng. Thay vì cài đặt trên từng máy chủ, Snort thường được đặt tại cửa ngõ mạng (như trên Firewall pfSense) để soi chiếu toàn bộ lưu lượng dữ liệu đi qua
- **Cơ chế hoạt động:** Snort phân tích các gói tin (packet) theo thời gian thực và so khớp chúng với một bộ quy tắc (rules/signatures) có sẵn. Nếu gói tin có chứa dấu hiệu của mã độc, quét cổng hay tấn công web, Snort sẽ lập tức phát ra cảnh báo. Trong đề án, dữ liệu cảnh báo của Snort sẽ được đẩy về cho Wazuh phân tích tổng hợp

Chương 2

Thiết kế và Triển khai hệ thống

2.1 Kiến trúc tổng thể của hệ thống

2.1.1 Sơ đồ tổng thể

Thay vì phụ thuộc vào VPN truyền thống hoặc các cơ chế xác thực dựa trên địa chỉ IP, hệ thống được xây dựng theo mô hình **Identity-Aware Proxy (IAP)**. Hệ thống sẽ kiểm tra danh tính người dùng trước khi cho phép truy cập, thay vì mặc định tin tưởng thiết bị đang nằm trong mạng nội bộ. Kiến trúc bảo mật của hệ thống được phân tách và quản lý theo hai mặt phẳng (plane) độc lập như sau:

- Mặt phẳng Điều khiển (Control/Management Plane): Chứa hạ tầng xác thực (Nginx, Authelia) và Giám sát (Wazuh).
- Mặt phẳng Dữ liệu (Data Plane): Chứa luồng traffic trực tiếp của khách thuê (Tenant VM, Database).
- Lúc này, Nginx/Authelia đóng vai trò là "cổng gác"(IAP) bảo vệ Control Plane.

2.1.2 Nguyên tắc thiết kế

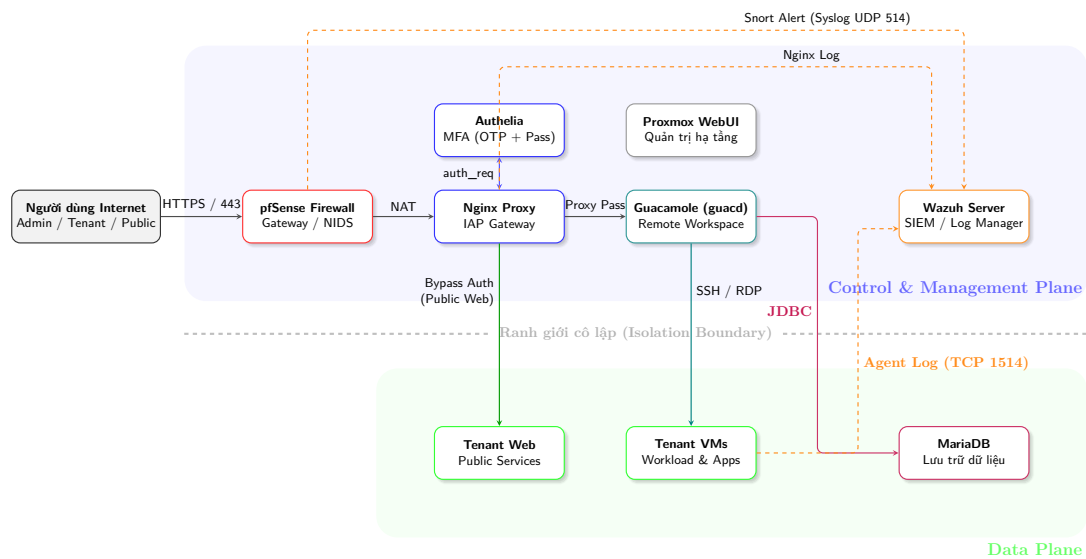
Hệ thống được xây dựng dựa trên các nguyên tắc bảo mật cơ bản nhằm giảm rủi ro và hạn chế mức độ ảnh hưởng khi xảy ra sự cố. Trong quá trình triển khai, nhóm ưu tiên các giải pháp dễ quản lý, phù hợp với mô hình thực tế và có thể mở rộng thêm sau này.

- **Xác thực bằng danh tính (Identity Authentication):** Hạn chế việc tin tưởng mặc định vào mạng nội bộ. Ở giai đoạn hiện tại, nhóm triển khai mô hình Identity-Aware Proxy (IAP) cho khu vực quản trị ở VLAN 10. Các truy cập đều phải xác thực đa yếu tố (MFA) trước khi vào hệ thống, thay vì chỉ dựa vào IP hoặc VPN như cách triển khai truyền thống.
- **Giới hạn quyền xuống mức tối thiểu (Least Privilege):** Hệ thống chỉ cho phép các kết nối thực sự cần thiết để dịch vụ hoạt động. Tại lớp gateway,

các rule được cấu hình theo hướng chặn mặc định (Default Deny), sau đó chỉ mở từng kết nối cụ thể giữa các dịch vụ. Ví dụ, kết nối từ vùng DMZ sang Database chỉ được phép qua đúng port cần sử dụng.

- **Phòng thủ theo chiều sâu (Defense in Depth):** Thay vì phụ thuộc vào một cơ chế bảo mật duy nhất, hệ thống triển khai nhiều lớp bảo vệ ở các vị trí khác nhau. Cụ thể gồm có giám sát lưu lượng mạng bằng Snort trên pfSense, xác thực truy cập qua Nginx và Authelia, phân tách mạng bằng VLAN và theo dõi log tập trung bằng Wazuh.
- **Tách biệt Control Plane và Data Plane (Plane Separation):** Hệ thống được thiết kế phân tách rõ ràng giữa luồng dữ liệu điều khiển và luồng dữ liệu dịch vụ nhằm đảm bảo tính toàn vẹn và hiệu suất:
 - *Mặt phẳng điều khiển (Control & Management Plane):* Bao gồm VLAN 10 (Gateway, Identity) và VLAN 20 (SIEM). Khu vực này chịu trách nhiệm xác thực, định tuyến, cấp phát tài nguyên ảo hóa và giám sát an ninh. Nó quyết định "lưu lượng sẽ đi đâu và ai được phép truy cập".
 - *Mặt phẳng dữ liệu (Data Plane):* Bao gồm VLAN 30 (DMZ Tenant) và VLAN 40 (Database). Đây là nơi thực thi các tác vụ tính toán thực tế của khách hàng và lưu trữ dữ liệu ứng dụng.

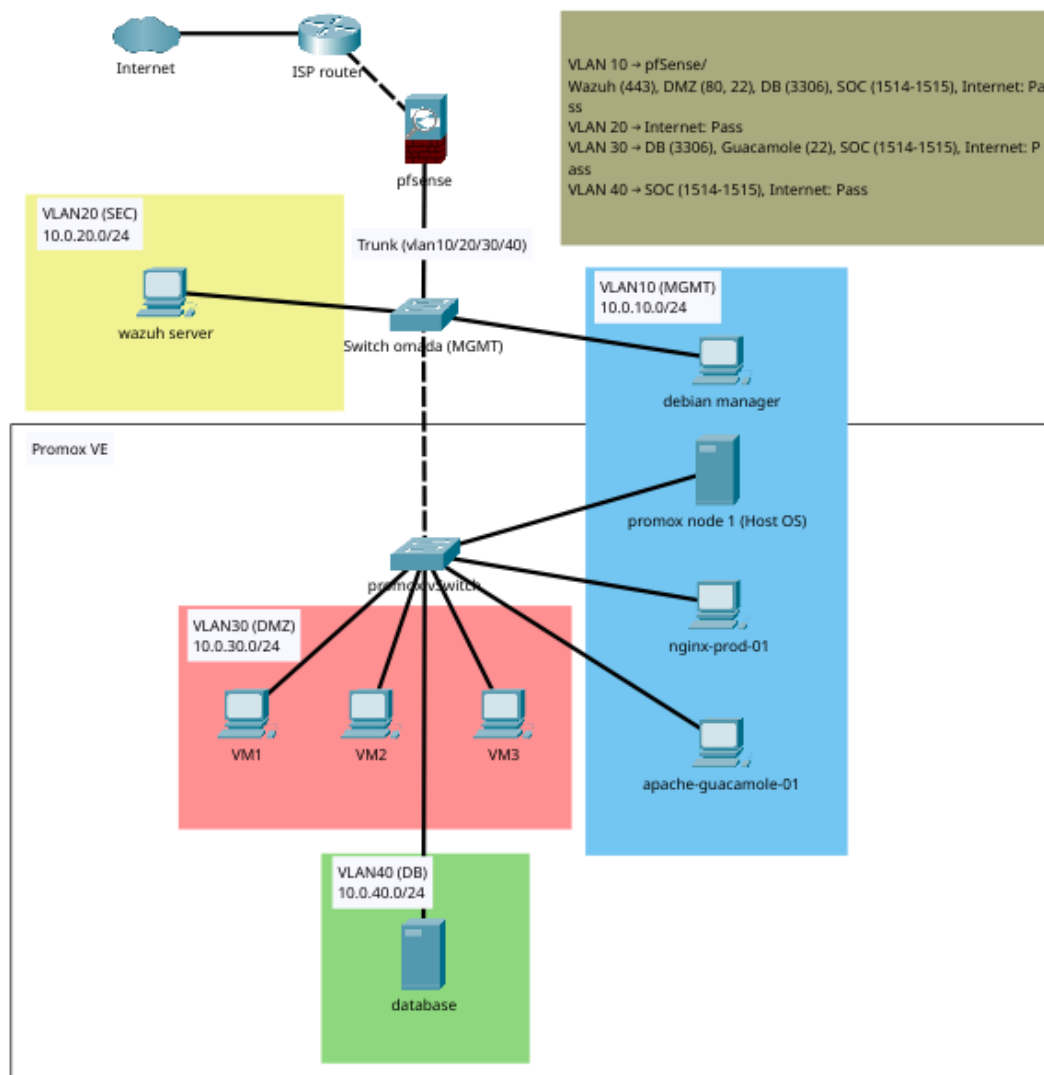
Việc tách biệt này giúp hệ thống khtống bị "nghẽn cổ chai". Ngay cả khi Data Plane chịu tải cao do lưu lượng web của khách thuê (Tenant) tăng đột biến, băng thông của Control Plane (như giao diện quản trị Proxmox hay luồng đẩy log về Wazuh) vẫn được bảo đảm không bị gián đoạn.



Hình 2.1: Sơ đồ tách biệt mặt phẳng

2.1.3 Môi trường và Hạ tầng triển khai

Hệ thống được triển khai kết hợp giữa thiết bị vật lý và môi trường ảo hóa nhằm tận dụng tài nguyên tốt hơn, đồng thời giúp việc quản lý và tách biệt các thành phần trong hệ thống dễ dàng hơn.



Hình 2.2: Sơ đồ cấu trúc liên kết mạng vật lý và môi trường ảo hóa

- **Thiết bị định tuyến và firewall (Gateway):** Hệ thống sử dụng một máy vật lý cài đặt **pfSense** để làm gateway trung tâm. pfSense sẽ làm các nhiệm vụ như NAT, định tuyến giữa các VLAN và quản lý kết nối trunk xuống Switch vật lý.
- **Máy chủ giám sát tập trung (Wazuh Server):** Wazuh được triển khai trên một máy vật lý riêng biệt để thu thập và phân tích log. Việc tách riêng thiết bị này giúp hệ thống giám sát hoạt động ổn định hơn và tránh bị ảnh hưởng khi các máy ảo phát sinh tải lớn.
- **Nền tảng ảo hóa (Proxmox VE):** Proxmox VE đóng vai trò là nền tảng ảo hóa chính của hệ thống, dùng để tạo và quản lý các máy ảo dịch vụ. Hệ

thống mạng bên trong Proxmox được cấu hình theo mô hình vSwitch và hỗ trợ VLAN để phân tách lưu lượng giữa các vùng mạng khác nhau.

2.1.4 Phân đoạn mạng và Chính sách kiểm soát

Ngoài việc chia mạng bằng VLAN, hệ thống còn dùng thêm **Proxmox Firewall** để kiểm soát kết nối giữa các máy ảo trong cùng một mạng, đặc biệt là ở vùng DMZ (VLAN 30).

Thay vì để các máy trong cùng VLAN có thể kết nối tự do với nhau, hệ thống sẽ đặt các rule để giới hạn những kết nối không cần thiết. Điều này giúp giảm nguy cơ lây lan nếu một máy bị tấn công hoặc bị khai thác, đồng thời tăng thêm mức độ an toàn cho mạng nội bộ theo hướng **Micro-segmentation**. Chi tiết quy hoạch dải IP cho từng vùng được thể hiện tại Bảng 2.1.

VLAN	Phân vùng	Dải địa chỉ IP	Chính sách truy cập và Chức năng
10	MGMT	10.0.10.0/24	Vùng Quản trị và Xác thực. Gồm giao diện quản trị của Proxmox Node, Nginx, Authelia, Pfsense, Switch. Chỉ cho phép kết nối tới các cổng 443 từ một số web gui
20	SEC	10.0.20.0/24	Vùng An ninh giám sát (Wazuh Server). Chỉ cho phép nhận kết nối qua cổng 1514/1515 từ các Agent.
30	DMZ	10.0.30.0/24	Vùng Dịch vụ Khách thuê. Bị chặn quyền truy cập ngược về VLAN 10 và 20. Cấm giao tiếp chéo giữa các máy ảo nội vùng để ngăn chặn di chuyển ngang.
40	DB	10.0.40.0/24	Vùng Cơ sở dữ liệu. Hoàn toàn cách ly với Internet. Chỉ chấp nhận kết nối từ các IP tĩnh thuộc VLAN 30 vào cổng dịch vụ (VD: 3306).

Bảng 2.1: Quy hoạch VLAN

Tại lớp mạng WAN, pfSense được cấu hình mặc định chặn toàn bộ kết nối từ

bên ngoài vào hệ thống. Các cổng quản trị trực tiếp như SSH (22/TCP) hay Remote Desktop (3389/TCP) đều không được mở ra Internet. Hệ thống chỉ cho phép duy nhất cổng 443/TCP để phục vụ kết nối HTTPS. Toàn bộ lưu lượng sau đó sẽ được NAT và chuyển tiếp đến máy ảo Nginx Reverse Proxy đặt trong VLAN 10 để tiếp tục xử lý xác thực và điều hướng truy cập. Chi tiết các rules thể hiện tại Phụ lục A.

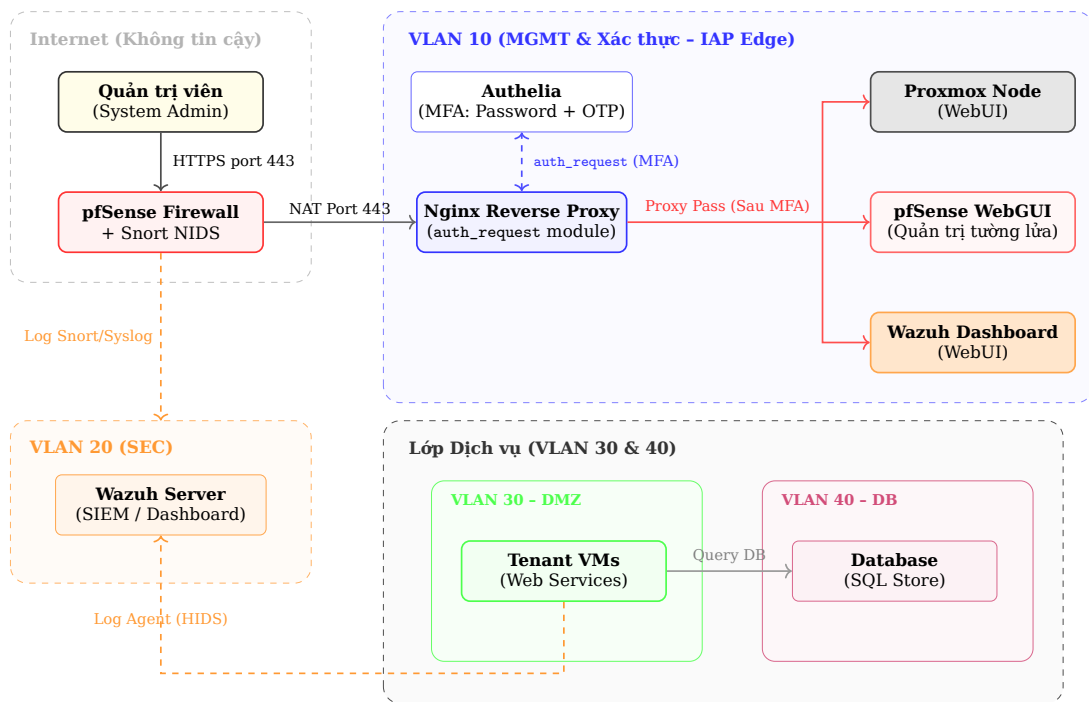
2.2 Luồng truy cập và phân phối dịch vụ

Để đáp ứng yêu cầu cung cấp dịch vụ Cloud linh hoạt nhưng vẫn đảm bảo an toàn, hệ thống được thiết kế với 3 luồng truy cập tách biệt, phục vụ cho 3 nhóm đối tượng khác nhau: Quản trị viên, Khách thuê dịch vụ (Tenant) và Người dùng cuối (End-user).

2.2.1 Luồng Quản trị viên (Identity-Aware Proxy)

Đây là luồng truy cập đặc quyền dành cho System Admin để quản trị hạ tầng lõi (Proxmox, pfSense, Wazuh).

- **Cơ chế hoạt động:** Truy cập bị chặn mặc định ở lớp mạng. Mọi kết nối đều phải đi qua cổng 443 của Nginx Reverse Proxy.
- **Xác thực Zero Trust:** Nginx được tích hợp module `auth_request` liên kết với Authelia. Quản trị viên bắt buộc phải vượt qua xác thực đa yếu tố (MFA) với Password và mã OTP mới được vào giao diện quản trị.

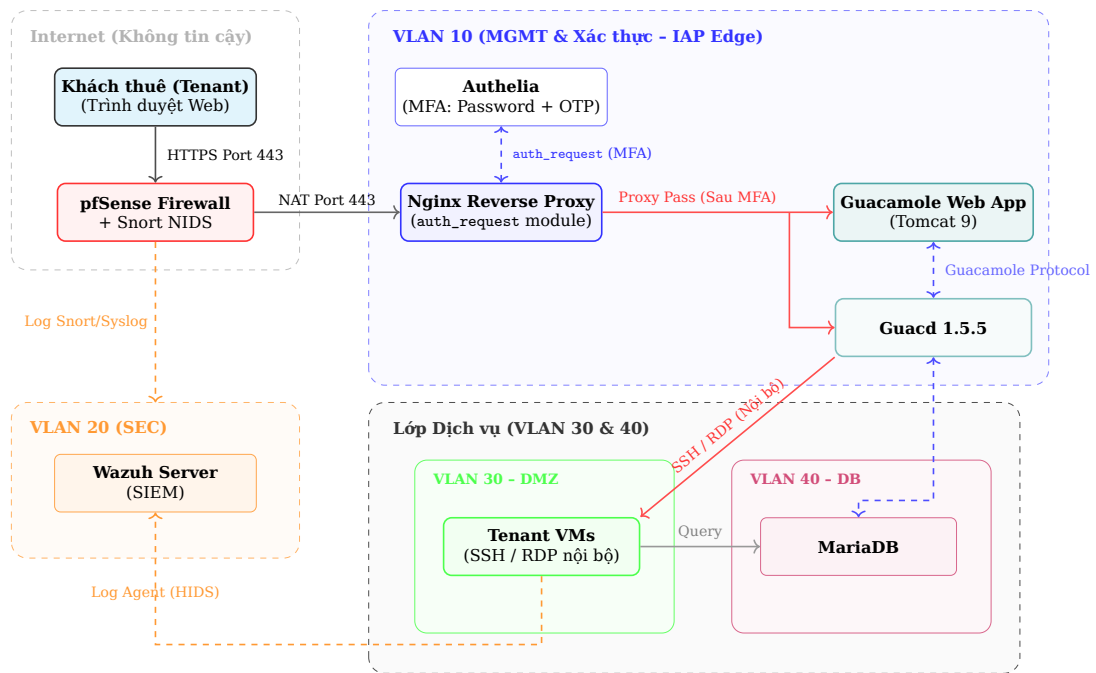


Hình 2.3: Luồng hoạt động của quản trị viên

2.2.2 Luồng Khách thuê (Remote Access Workspace)

Để khách thuê có thể quản trị máy ảo của họ mà không cần cấp VPN hay mở trực tiếp các cổng nhảy cảm (SSH/RDP) ra Internet, hệ thống triển khai **Apache Guacamole** (Guacd 1.5.5) làm cổng Remote Desktop mà không yêu cầu cài đặt trên máy người sử dụng.

- **Xử lý tương thích hệ thống:** Dịch vụ Guacd được biên dịch trực tiếp từ mã nguồn trên Debian 12 và cấu hình ép lắng nghe trên IPv4 (127.0.0.1) thay vì IPv6 mặc định. Web App được vận hành thông qua Tomcat 9.
- **Cơ chế Stream & Proxy:** Nginx đóng vai trò Proxy bọc ngoài nhằm truyền tải giao diện guacd tới Tenant.
- **Phân quyền Multi-Tenant:** Luồng truy cập này cũng phải đi qua Authelia MFA. Tuy nhiên, sau khi vào được Guacamole, cơ sở dữ liệu MariaDB (tại VLAN 40) sẽ xét quyền của tenant đó. Mỗi tenant chỉ nhìn thấy và điều khiển duy nhất máy ảo thuộc về họ. Tính năng SFTP cũng được bật để tenant tải file trực tiếp qua giao diện web.

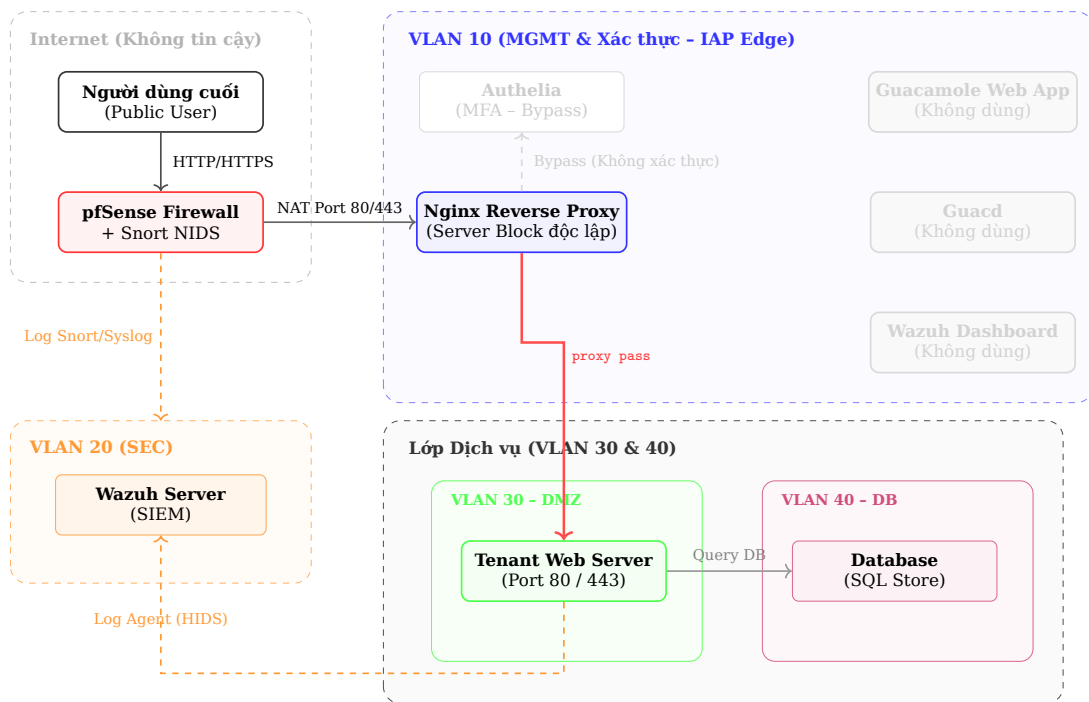


Hình 2.4: Luồng hoạt động của khách thuê

2.2.3 Luồng Người dùng cuối (Public Web Access)

Đối với các dịch vụ Web Server do khách thuê tự Host tại vùng DMZ (VLAN 30), hệ thống hoạt động tương tự nhưng sẽ không có authelia can thiệp yêu cầu xác minh.

- **Cấu hình Bypass Proxy:** Một file cấu hình Server Block độc lập được tạo trên Nginx dành riêng cho tên miền công khai (VD: ela.domain.com). Luồng này sử dụng proxy_pass đâm thẳng xuống địa chỉ IP máy ảo của khách thuê (VLAN 30).
- **Kiểm soát bằng Firewall:** Tường lửa pfSense tại lớp gateway sẽ mở rule riêng, cho phép lưu lượng từ IP của Nginx (VLAN 10) truy cập thẳng xuống IP mục tiêu tại vùng DMZ qua cổng 80/443, tách biệt hoàn toàn với vùng xác thực quản trị.



Hình 2.5: Luồng hoạt động của người dùng cuối

2.3 Triển khai Cấu hình Chi tiết

2.3.1 Triển khai tường lửa và định tuyến

Tường lửa pfSense đóng vai trò là chốt chặn an ninh đầu tiên (Gateway) và là trung tâm định tuyến (Core Router) cho toàn bộ hệ thống mạng vật lý lẫn ảo hóa. Quá trình cấu hình được chia thành các hạng mục cốt lõi sau:

1. Thiết lập Giao diện mạng (Interfaces) và Trunking

- WAN (Giao diện ngoại mạng): Được cấu hình nhận địa chỉ IP từ nhà cung cấp dịch vụ (ISP), đóng vai trò là cửa ngõ giao tiếp duy nhất giữa hệ thống nội bộ và Internet.
- LAN (Giao diện nội mạng) & VLAN Trunking: Cổng LAN vật lý trên pfSense được cấu hình ở chế độ Trunking (chuẩn 802.1Q) kết nối trực tiếp xuống Switch quản lý. Trên giao diện vật lý này, các Sub-interfaces (giao diện mạng con) được khởi tạo tương ứng với các VLAN ID (10, 20, 30, 40). Thông qua đó, pfSense đóng vai trò là Default Gateway đảm nhiệm việc định tuyến cho từng vùng mạng độc lập.

2. Cấu hình Dịch địa chỉ mạng (NAT) và Port Forwarding

Theo nguyên tắc đặc quyền tối thiểu (Least Privilege), pfSense áp dụng chính sách chặn mặc định (Default Deny) đối với toàn bộ lưu lượng Ingress (từ Internet đi vào hệ thống).

- Nhằm đảm bảo an toàn, hệ thống không mở trực tiếp bất kỳ cổng quản trị nào (như SSH - port 22, hay RDP - port 3389) ra ngoài Internet. Dịch vụ duy nhất được phép tiếp nhận kết nối là HTTPS (Cổng 443/TCP).
- Hệ thống sử dụng cơ chế NAT Port Forward để dịch chuyển toàn bộ các gói tin nhắm đến IP WAN tại cổng 443 xuyên qua tường lửa, sau đó chuyển tiếp (forward) trực tiếp tới địa chỉ IP nội bộ của máy chủ Nginx Reverse Proxy (10.0.10.12) nằm tại vùng VLAN 10 để xử lý bước tiếp theo.

3. Thiết lập Chính sách Tường lửa (Firewall Rules) nội bộ

Luồng lưu lượng giữa các VLAN (Inter-VLAN Routing) được kiểm soát chặt chẽ thông qua các tập luật (rules) trên pfSense nhằm chống lại rủi ro di chuyển ngang (Lateral Movement) của tin tặc:

- Vùng Quản trị (VLAN 10): Được cấp quyền truy cập ra Internet để tải các bản cập nhật, đồng thời có quyền khởi tạo kết nối (Egress) đến các VLAN khác để thực thi tác vụ quản trị hạ tầng.
- Vùng Dịch vụ (VLAN 30) & CSDL (VLAN 40): Bị cấm hoàn toàn quyền khởi tạo kết nối ngược lên vùng Quản trị (VLAN 10) và vùng Giám sát an ninh (VLAN 20). Việc giao tiếp giữa VLAN 30 và VLAN 40 cũng được thiết lập quy tắc tĩnh, chỉ cho phép các IP thuộc vùng DMZ truy cập vào vùng Database qua đúng cổng dịch vụ cơ sở dữ liệu đã được cấp phép (VD: 3306/TCP).

(Chi tiết về bảng tổng hợp tập luật tường lửa được đính kèm tại Phụ lục A).

2.3.2 Triển khai lớp xác thực IAP (Nginx & Authelia)

Lớp Identity-Aware Proxy (IAP) được đặt tại VLAN 10 và đóng vai trò là lớp kiểm tra danh tính trước khi người dùng có thể vào các dịch vụ quản trị bên trong hệ thống.

1. Cấu hình Nginx làm Reverse Proxy và SSL

Nginx được sử dụng làm Reverse Proxy để tiếp nhận toàn bộ kết nối HTTPS từ Internet và điều hướng đến các dịch vụ nội bộ tương ứng.

- **Tiếp nhận lưu lượng:** Nginx được cấu hình lắng nghe tại cổng 443 cho các kết nối HTTPS. Các truy cập qua cổng 80 sẽ tự động được chuyển hướng sang HTTPS để đảm bảo dữ liệu truyền đi được mã hóa.
- **Cấu hình SSL:** Trong môi trường thử nghiệm, hệ thống sử dụng chứng chỉ tự ký được tạo bằng OpenSSL. Việc này giúp mã hóa lưu lượng giữa người dùng và hệ thống.
- **Điều hướng dịch vụ (Proxy Pass):** Nginx sử dụng các file cấu hình `site-confs` để ánh xạ từng subdomain đến đúng dịch vụ bên trong. Ví dụ, các tên miền như `auth.domain.com` hoặc `proxmox.domain.com` sẽ được chuyển tiếp đến IP và cổng tương ứng của từng máy ảo trong hệ thống.

Chi tiết về quy hoạch tên miền, máy chủ đích và chính sách xác thực MFA qua hệ thống Reverse Proxy được tóm tắt tại Bảng 2.2.

Tên miền (Subdomain)	Dịch vụ (Target)	IP & Port đích	Yêu cầu MFA
portal.tapama.cloud	Apache Guacamole (Cổng Remote Workspace cho Khách thuê)	10.0.10.13:8080	Có
pve.tapama.cloud	Proxmox Node (Giao diện quản trị ảo hóa)	10.0.10.11:8006	Có
soc.tapama.cloud	Wazuh Dashboard (Hệ thống giám sát SIEM)	10.0.20.10:443	Có
ela.tapama.cloud	Public Web Server của Khách thuê (Vùng DMZ)	10.0.30.50:80	Không

Bảng 2.2: Cấu hình định tuyến Nginx Reverse Proxy

2. Tích hợp Authelia để xác thực tập trung và MFA

Authelia được sử dụng kết hợp với Nginx để quản lý đăng nhập và kiểm soát truy cập cho các dịch vụ quản trị trong hệ thống.

- **Xác thực đa yếu tố (MFA):** Hệ thống yêu cầu người dùng đăng nhập bằng mật khẩu và thêm một bước xác thực OTP. Mã OTP có thể được lấy từ các ứng dụng như Google Authenticator hoặc FreeOTP nhằm tăng độ an toàn cho tài khoản quản trị.
- **Kiểm tra xác thực qua Nginx:** Tại các đường dẫn cần bảo vệ, Nginx sẽ gửi yêu cầu kiểm tra đăng nhập sang Authelia thông qua cơ chế `auth_request`. Nếu người dùng chưa xác thực hoặc không đủ quyền truy cập, kết nối sẽ bị từ chối. Còn nếu xác thực thành công thì yêu cầu sẽ được chuyển tiếp vào dịch vụ bên trong.
- **Quản lý phiên đăng nhập:** Authelia quản lý phiên làm việc bằng Cookie. Nhờ đó, người dùng chỉ cần đăng nhập một lần là có thể sử dụng nhiều dịch vụ quản trị khác nhau trong cùng phiên làm việc mà không cần xác thực lại nhiều lần.

2.3.3 Triển khai dịch vụ lõi (Guacamole, Tomcat 9 & MariaDB)

Đây là phân hệ hạt nhân của toàn bộ kiến trúc cung cấp dịch vụ, chịu trách nhiệm khởi tạo, duy trì và phân phối các phiên kết nối từ xa (Remote Desktop/SSH) cho khách thuê mà không yêu cầu cài đặt phần mềm tác nhân (agent) trên thiết bị đầu cuối.

1. Biên dịch và cấu hình nhân điều khiển (guacd 1.5.5)

Thay vì sử dụng các gói nhị phân có sẵn, dịch vụ lõi `guacd` được biên dịch trực tiếp từ mã nguồn trên nền tảng Debian 12. Quá trình này đảm bảo tính toàn vẹn và tích hợp đầy đủ các thư viện giao thức cần thiết bao gồm RDP, SSH, VNC và đặc biệt là Pango để kết xuất văn bản độ phân giải cao trong môi trường dòng lệnh.

Trong quá trình khởi chạy dịch vụ, một vấn đề tương thích mạng đã phát sinh khi tiến trình `guacd` tự động liên kết (bind) vào địa chỉ IPv6 loopback (`:::1`), dẫn đến việc Web Application không thể giao tiếp với engine lõi. Giải pháp được áp dụng là can thiệp vào tệp cấu hình `/etc/guacamole/guacd.conf`, ép buộc tiến trình chỉ lắng nghe trên giao diện IPv4 (`127.0.0.1`), từ đó khôi phục hoàn toàn luồng kết nối nội bộ.

2. Tích hợp môi trường thực thi Web (Tomcat 9)

Kiến trúc Guacamole 1.5.5 yêu cầu môi trường Java Servlet tương thích. Tuy nhiên, hệ điều hành Debian 12 đã chính thức loại bỏ Tomcat 9 khỏi kho lưu

trữ mặc định, trong khi hệ thống Guacamole hiện tại chưa hỗ trợ toàn diện cho Tomcat 10.

Để vượt qua rào cản này, hệ thống áp dụng phương pháp triển khai độc lập (Standalone Deployment). Các tệp tin nhị phân của Tomcat 9 được tải xuống và cấu hình thủ công tại thư mục `/opt/tomcat`. Nhằm đảm bảo tính ổn định và khả năng quản lý vòng đời của dịch vụ, một kịch bản **Systemd Service** (`tomcat.service`) đã được viết riêng để vận hành Tomcat như một tiến trình ngầm của hệ thống. Tệp thực thi `guacamole.war` sau đó được liên kết tượng trưng (symlink) vào thư mục `webapps` của Tomcat để tự động giải nén và khởi chạy.

3. Đồng bộ Cơ sở dữ liệu và Phân quyền (MariaDB)

Dữ liệu về cấu hình máy ảo, thông tin người dùng và phân quyền (RBAC) được lưu trữ tập trung tại máy chủ MariaDB thuộc VLAN 40.

- **Kết nối xuyên vùng:** Hệ thống sử dụng thư viện JDBC MySQL (Connector-J) để thiết lập luồng giao tiếp dữ liệu. Tệp `guacamole.properties` được cấu hình để trở định tuyến truy vấn xuyên qua tường lửa nội bộ xuống địa chỉ IP `10.0.40.13`.
- **Thiết lập cấu trúc (Schema):** Cấu trúc bảng và dữ liệu khởi tạo của Guacamole được nạp trực tiếp vào MariaDB. Ngay sau khi kết nối thành công, tài khoản mặc định `guacadmin` lập tức bị vô hiệu hóa và thay thế bằng tài khoản đặc quyền cấp cao (`tapama_root`) nhằm triệt tiêu rủi ro từ các cuộc tấn công dò quét mật khẩu mặc định.

2.3.4 Triển khai giám sát tập trung

Để có thể theo dõi và xử lý các sự kiện an ninh từ nhiều nguồn khác nhau (nginx, pfsense, ...), hệ thống cần có cơ chế đồng bộ và chuẩn hóa dữ liệu trước khi gửi về máy chủ trung tâm.

Để đảm bảo khả năng giám sát toàn diện, hệ thống thu thập log từ nhiều nguồn khác nhau với các giao thức và định dạng đặc thù. Bảng 2.3 mô tả các dạng dữ liệu được đẩy về Wazuh Manager.

Nguồn Log (Log Source)	Giao thức	Cổng	Định dạng dữ liệu (Format)
pfSense Firewall (Snort NIDS)	UDP	514	Syslog / Snort Alert Format (Yêu cầu Custom Decoder)
Tenant VMs (Debian/Ubuntu)	TCP	1514	Wazuh Encrypted Message (auth.log, syslog)
Nginx Reverse Proxy	TCP	1514	Wazuh Encrypted Message (access.log, error.log)
MariaDB Database Server	TCP	1514	Wazuh Encrypted Message (mysql-error.log)

Bảng 2.3: Các nguồn chính cần giám sát tập trung

- **Cấu hình đẩy sự kiện NIDS:** pfSense được cấu hình dịch vụ Syslog để chuyển tiếp theo thời gian thực tệp `snort.alert` đến địa chỉ IP của Wazuh Manager thông qua giao thức UDP cổng 514.
- **Cấu hình thu thập HIDS:** Các Wazuh Agent trên máy ảo mục tiêu liên tục theo dõi tệp nhật ký hệ thống (`/var/log/syslog`, `auth.log`) và gửi về trung tâm qua giao thức mã hóa trên cổng 1514/TCP.

2.4 Tối ưu hóa và Khắc phục sự cố trong quá trình triển khai

2.4.1 Khắc phục bất đồng bộ định dạng Log giữa Snort và Wazuh

- **Vấn đề:** pfSense đã chuyển tiếp (forward) log Syslog thành công qua cổng 514, nhưng trên Wazuh Dashboard không hiển thị được các trường dữ liệu chi tiết như IP nguồn, IP đích hay tên cảnh báo.
- **Nguyên nhân:** Định dạng Syslog mặc định đẩy ra từ pfSense có tiền tố (prefix) không khớp hoàn toàn với bộ giải mã (Decoder) mặc định của Wazuh dành cho Snort.
- **Khắc phục:** Cấu hình lại dịch vụ đẩy log trên pfSense để gửi log dưới dạng định dạng chuẩn của Snort (Snort alert format), hoặc tạo một Decoder tùy

chỉnh (Custom Decoder) trên Wazuh Server để biểu thức chính quy (Regex) bắt đúng các trường dữ liệu từ log pfSense đẩy về.

2.4.2 Xử lý lỗi mất dịch vụ WebGUI trên pfSense

- **Vấn đề:** Khi truy cập vào giao diện web của pfSense, trình duyệt báo lỗi "Not Found" hoặc "502 Bad Gateway", các dịch vụ định tuyến vẫn chạy nhưng không thể quản trị do tiến trình PHP bị ngắt.
- **Nguyên nhân:** Do sử dụng bộ chuyển đổi USB sang LAN (USB-to-RJ45) chất lượng kém để mở rộng cổng mạng cho máy vật lý. Thiết bị này hoạt động không ổn định, gây mất gói tin liên tục ở tầng vật lý khiến hệ thống bị treo tiến trình WebGUI.
- **Khắc phục:** Thay thế bằng đầu chuyển đổi USB-LAN chất lượng tốt hơn, đồng thời tắt bớt các Widget giám sát thời gian thực (Traffic Graphs, System Info) trên Dashboard của pfSense để giảm tải cho dịch vụ PHP-FPM.

2.4.3 Xử lý máy chủ Wazuh sập nguồn/treo hệ thống do quá tải

- **Vấn đề:** Dịch vụ Wazuh Manager đột ngột dừng hoạt động và không thể khởi động lại.
- **Nguyên nhân:** Kiến trúc của Wazuh (đặc biệt là thành phần Wazuh Indexer/Elasticsearch) đòi hỏi tài nguyên RAM và CPU cực kỳ lớn để xử lý dữ liệu. Cấu hình mặc định vượt quá khả năng đáp ứng của máy chủ vật lý đang sử dụng.
- **Khắc phục:** Tiến hành tối ưu hóa lại hệ thống. Bóp bớt yêu cầu hiệu năng bằng cách giới hạn kích thước bộ nhớ của Indexer và vô hiệu hóa các module không thực sự cần thiết để hệ thống chạy ổn định trên tài nguyên giới hạn.

2.4.4 Nghẽn cổ chai băng thông (Network Bottleneck) trên pfSense

- **Vấn đề:** Tốc độ mạng nội bộ và truy cập Internet đi qua Gateway rất chậm, ảnh hưởng đến toàn bộ hệ thống.
- **Nguyên nhân:** Kiểm tra phần cứng phát hiện cổng USB trên máy vật lý dùng để cắm card mạng LAN mở rộng cho pfSense chỉ hỗ trợ chuẩn USB 2.0 (bằng

thông tối đa lý thuyết thấp), không đủ sức gánh lưu lượng định tuyến của toàn hệ thống.

- **Khắc phục:** Thay đổi thiết kế triển khai. Tráo đổi vai trò giữa hai máy vật lý: chuyển Wazuh Server sang cài trên máy có cổng USB 2.0 (do Wazuh chỉ nhận log, không yêu cầu băng thông mạng quá lớn), và cài đặt lại pfSense sang máy trước đó cài wazuh do có cổng USB 3.0. Điều này giải quyết triệt để tình trạng nghẽn băng thông.

2.5 Kết luận chương

Chương 2 đã hoàn thành mục tiêu thiết lập nền tảng **công nghệ** (Technology) vững chắc cho mô hình **Trung tâm Điều hành An ninh mạng** (SOC). Thay vì chỉ triển khai các công cụ giám sát một cách rời rạc, đồ án đã tích hợp thành công hệ thống phát hiện xâm nhập mạng **Snort** (NIDS) và nền tảng quản lý sự kiện an ninh thông tin **Wazuh** (SIEM/HIDS) vào một kiến trúc mạng **Zero Trust** có tính phân lập cao.

Kiến trúc **phân đoạn mạng** (Micro-segmentation) với 4 vùng **VLAN** riêng biệt và lớp kiểm soát định danh **Identity-Aware Proxy** (Nginx/Authelia) không chỉ giải quyết bài toán cung cấp dịch vụ an toàn cho khách thuê, mà còn tạo ra các “điểm chốt chặn” (*choke points*) chiến lược. Nhờ đó, luồng dữ liệu nhật ký (*log*) thu thập được từ pfSense, Nginx, Guacamole và các máy ảo đầu cuối trở nên sạch sẽ, có độ tin cậy cao và loại bỏ được các rủi ro nhiễu loạn thông tin.

Bên cạnh đó, việc khắc phục triệt để các sự cố nghẽn băng thông vật lý, xử lý bất đồng bộ định dạng giải mã (**Custom Decoder** cho pfSense) và tối ưu hóa tài nguyên phần cứng cho cụm **Wazuh Indexer** đã giúp hệ thống SOC đạt được độ sẵn sàng và ổn định cần thiết để thu thập dữ liệu theo thời gian thực.

Tuy nhiên, một mô hình SOC hoàn chỉnh không chỉ dừng lại ở nền tảng công nghệ mà còn đòi hỏi các **quy trình vận hành và xử lý sự cố** (Process) rõ ràng. Với hạ tầng giám sát tập trung đã được thiết lập chặt chẽ tại Chương 2, hệ thống đã sẵn sàng bước vào Chương 3 để triển khai các kịch bản thực nghiệm tấn công, đánh giá năng lực phân tích tương quan và xây dựng **quy trình phản ứng sự cố** (Incident Response) chuẩn mực của một SOC thực thụ.

Chương 3

Thực nghiệm

3.1 Phương pháp thực nghiệm

Phần này trình bày phương pháp thiết lập môi trường tấn công giả lập và cách bố trí các thành phần giám sát để đo đặc năng lực phát hiện của hệ thống SOC theo thời gian thực.

- **Môi trường thử nghiệm:** Thử nghiệm được thực hiện trên không gian mạng nội bộ. Máy tấn công được đặt ở WAN, đóng vai trò là một tác nhân độc hại cố gắng xâm nhập xuyên qua Gateway để tiếp cận các máy ảo trong vùng DMZ
- **Thiết bị và Công cụ sử dụng:** Máy tấn công sử dụng hệ điều hành Arch Linux, trang bị các công cụ kiểm thử bảo mật tiêu chuẩn (Nmap, ffuf, Nikto). Hệ thống phòng thủ bao gồm Tường lửa pfSense tích hợp NIDS (Snort) tại cổng WAN, Nginx Reverse Proxy làm cổng gác, và SIEM Wazuh đóng vai trò trung tâm phân tích nhật ký

3.2 Kịch bản 1: Aggressive enumeration scan

3.2.1 Mục tiêu

Mục tiêu của kịch bản này là để kiểm tra và đánh giá khả năng phản ứng của hệ thống giám sát khi xảy ra dò quét cổng dịch vụ mức độ cơ bản, ở đây là Aggressive enumeration scan

- Máy tấn công (Attacker): Chạy Arch Linux, IP 192.168.1.15
- Mục tiêu (Target): Địa chỉ IP WAN của tường lửa pfSense (192.168.1.50)
- Công cụ sử dụng: Nmap

3.2.2 Tiến hành thực nghiệm:

Từ máy tấn công, thực thi lệnh Nmap:

```
1 sudo nmap -sS -p- -T4 -A 192.168.1.50
```

Trong đó:

- **-sS**: Thực hiện SYN Scan nhằm hạn chế hoàn tất kết nối TCP đầy đủ
- **-p-**: Quét toàn bộ 65535 port
- **-T4**: Tăng tốc độ scan (aggressive timing)
- **-A**: Aggressive detection: OS detection, version detection, script scan, traceroute

Lệnh trên có ưu điểm là rất đầy đủ thông tin, kiểm tra dịch vụ đang chạy, xác định hệ điều hành và tìm lỗ hổng sơ bộ. Nhưng nhược điểm là dễ bị phát hiện nên phù hợp để thực nghiệm ở mức độ cơ bản

```

root@kali:~# sudo nmap -sS -p- -T4 -A 192.168.1.50
Starting Nmap 7.99 ( https://nmap.org ) at 2024-05-13 05:48 +0700
Nmap scan report for auth.tapana.cloud (192.168.1.50)
Host is up (0.0020s latency).
Not shown: 65532 filtered ports (no-response)
PORT      STATE SERVICE VERSION
80/tcp    open  HTTP      nginx/1.22.1
|_ http-server-header: nginx/1.22.1
|_ http-trace-info: Problem with XML parsing of /evon/about
|_ http-title: Site doesn't have a title (text/html; charset=utf-8).
443/tcp    open  SSL/TLS   nginx/1.22.1
|_ http-server-header: nginx/1.22.1
|_ http-title: Site doesn't have a title (text/html; charset=utf-8).
|_ ssl-date: TLS randomness does not represent time
|_ ssl-cert: Subject: commonName=auth.tapana.cloud/organizationName=Tapana/StateOrProvinceName=Dung Nai/countryName=VN
|_ Not valid before: 2024-05-01T18:02:13
|_ Not valid after: 2027-05-01T18:02:13
|_ tls-alpn:
|_ http/1.1
|_ http/2.0
|_ http/3.0
|_ http/3.1
|_ http/3.2
|_ http/3.3
|_ http/3.4
|_ http/3.5
|_ http/3.6
|_ http/3.7
|_ http/3.8
|_ http/3.9
|_ http-trace-info: Problem with XML parsing of /evon/about
MAC Address: 8C:12:18:18:18:17 (Panasonic AC Network Company)
Warning: OSScan results may be unreliable because we could not find at least 1 open and 1 closed port
Device type: general purpose
Running (JUST GUESSED): Linux 4.X|6.X|8.X|2.6.X|3.X (92%)
OS CPE: cpe:/o:linux:linux_kernel:4 cpe:/o:linux:linux_kernel:6.1 cpe:/o:linux:linux_kernel:5 cpe:/o:linux:linux_kernel:2.6.32 cpe:/o:linux:linux_kernel:3.10
Aggressive OS guesses: linux 4.19 - 5.19 (92%), linux 6.1 (70%), linux 4.15 - 5.19 (60%), linux 5.0 - 5.16 (60%), linux 2.6.32 (50%), linux 2.6.32 or 3.10 (40%)
No exact OS matches for host (test conditions non-ideal).
Network Distance: 1 hop

TRACEROUTE
Hop RTT ADDRESS
1 2.50 ms auth.tapana.cloud (192.168.1.50)

OS and Service detection performed. Please report any incorrect results at https://nmap.org/submit/ .
Nmap done: 1 IP address (1 host up) scanned in 109.99 seconds

```

Hình 3.1: Nmap Aggressive enumeration scan

3.2.3 Kết quả thực nghiệm

Bảng 3.1: So sánh kết quả phát hiện theo loại rà quét

Loại rà quét	Công cụ phát hiện	Mức độ cảnh báo
Aggressive (-A)	Wazuh Agent (Nginx)	Level 10 (Rule 31151)
Stealth / Decoy (-sS -f)	Snort NIDS (pfSense)	Level 8 (Rule 100002)
Background Noise thực tế	Custom Decoder + Wazuh	Level 8 (Rule 100002)

Các hành vi bị hệ thống giám sát ghi nhận và phân tích cảnh báo ở cả 2 tầng mạng và tầng ứng dụng

- **Snort trên pfSense:** Phát hiện kẻ tấn công scan các cổng dịch vụ cơ sở dữ liệu (MySQL, MSSQL, PostgreSQL, Oracle) và cổng VNC. Bên cạnh đó, Snort đọc được chữ ký của gói tin và nhận diện đích danh công cụ Nmap, từ đó kích hoạt các cảnh báo *NMAP OS Detection Probe* và *Nmap Scripting Engine User-Agent Detected* ở level 8 (Mức độ High)
- **Wazuh Agent trên Nginx:** Nmap Aggressive đã gửi các truy vấn HTTP lỗi khiến Nginx liên tục trả về mã 400. SIEM đã tự động phân tích tương quan khi thấy hàng loạt lỗi 400 từ cùng một IP (192.168.1.15) và đẩy rule level từ 5 lên 10 cùng với cảnh báo *Multiple web server 400 error codes from same source ip*, kèm theo định dạng kỹ thuật MITRE T1595.002

timestamp	agent.name	rule.description	rule.level	rule.id	data.scrip	data.dstip	data.dstport	rule.mitre.id
May 13, 2026 @ 05:41:52.8...	debian-wazuh	Syslogd restarted.	5	1005	-	-	-	
May 13, 2026 @ 05:41:26.5...	nginx-prod-01	Web server 400 error code.	5	31101	192.168.1.15	-	-	
May 13, 2026 @ 05:41:25.8...	debian-wazuh	pfSense Snort: ET SCAN Nmap Scripting Engine User-Agent Detected (Nmap Scripting Engine)	8	100002	192.168.1.15	192.168.1.50	80	T1046
May 13, 2026 @ 05:41:25.8...	debian-wazuh	pfSense Snort: ET SCAN Nmap Scripting Engine User-Agent Detected (Nmap Scripting Engine)	8	100002	192.168.1.15	192.168.1.50	80	T1046
May 13, 2026 @ 05:41:25.8...	debian-wazuh	pfSense Snort: ET SCAN Nmap Scripting Engine User-Agent Detected (Nmap Scripting Engine)	8	100002	192.168.1.15	192.168.1.50	80	T1046
May 13, 2026 @ 05:41:25.8...	debian-wazuh	pfSense Snort: ET SCAN Nmap Scripting Engine User-Agent Detected (Nmap Scripting Engine)	8	100002	192.168.1.15	192.168.1.50	80	T1046
May 13, 2026 @ 05:41:24.8...	debian-wazuh	pfSense Snort: ET SCAN Nmap Scripting Engine User-Agent Detected (Nmap Scripting Engine)	8	100002	192.168.1.15	192.168.1.50	80	T1046
May 13, 2026 @ 05:41:24.8...	debian-wazuh	pfSense Snort: ET SCAN Nmap Scripting Engine User-Agent Detected (Nmap Scripting Engine)	8	100002	192.168.1.15	192.168.1.50	80	T1046
May 13, 2026 @ 05:41:24.8...	debian-wazuh	pfSense Snort: ET SCAN Nmap Scripting Engine User-Agent Detected (Nmap Scripting Engine)	8	100002	192.168.1.15	192.168.1.50	80	T1046

Hình 3.2: Snort phát hiện Nmap Scripting Engine (Level 8)

timestamp	agent.name	rule.description	rule.level	rule.id	data.scrip	data.dstip	data.dstport	rule.mitre.id
May 13, 2026 @ 05:41:24.5...	nginx-prod-01	Web server 400 error code.	5	31101	192.168.1.15	-	-	
May 13, 2026 @ 05:41:24.5...	nginx-prod-01	Web server 400 error code.	5	31101	192.168.1.15	-	-	
May 13, 2026 @ 05:41:24.5...	nginx-prod-01	Web server 400 error code.	5	31101	192.168.1.15	-	-	
May 13, 2026 @ 05:41:24.5...	nginx-prod-01	Web server 400 error code.	5	31101	192.168.1.15	-	-	
May 13, 2026 @ 05:41:24.5...	nginx-prod-01	Web server 400 error code.	5	31101	192.168.1.15	-	-	
May 13, 2026 @ 05:41:23.7...	debian-wazuh	pfSense Snort: ET SCAN NMAP OS Detection Probe	8	100002	192.168.1.15	192.168.1.50	43104	T1046
May 13, 2026 @ 05:41:23.7...	debian-wazuh	pfSense Snort: ET SCAN NMAP OS Detection Probe	8	100002	192.168.1.15	192.168.1.50	43104	T1046
May 13, 2026 @ 05:41:23.7...	debian-wazuh	pfSense Snort: ET SCAN NMAP OS Detection Probe	8	100002	192.168.1.15	192.168.1.50	43104	T1046
May 13, 2026 @ 05:41:21.7...	debian-wazuh	pfSense Snort: ET SCAN NMAP OS Detection Probe	8	100002	192.168.1.15	192.168.1.50	35640	T1046
May 13, 2026 @ 05:41:21.7...	debian-wazuh	pfSense Snort: ET SCAN NMAP OS Detection Probe	8	100002	192.168.1.15	192.168.1.50	35640	T1046
May 13, 2026 @ 05:41:21.7...	debian-wazuh	pfSense Snort: ET SCAN NMAP OS Detection Probe	8	100002	192.168.1.15	192.168.1.50	35640	T1046
May 13, 2026 @ 05:41:20.6...	debian-wazuh	pfSense Snort: ET SCAN NMAP OS Detection Probe	8	100002	192.168.1.15	192.168.1.50	35640	T1046
May 13, 2026 @ 05:41:03.0...	debian-wazuh	pfSense Snort: ET SCAN Suspicious inbound to MSSQL port 1433	8	100002	192.168.1.15	192.168.1.50	1433	T1046
May 13, 2026 @ 05:41:03.0...	debian-wazuh	pfSense Snort: ET SCAN Suspicious inbound to MSSQL port 1433	8	100002	192.168.1.15	192.168.1.50	1433	T1046
May 13, 2026 @ 05:40:52.7...	debian-wazuh	Syslogd restarted.	5	1005	-	-	-	
May 13, 2026 @ 05:40:51.6...	debian-wazuh	pfSense Snort: ET SCAN Potential VNC Scan 5800-5820	8	100002	192.168.1.15	192.168.1.50	5820	T1046
May 13, 2026 @ 05:40:31.8...	debian-wazuh	pfSense Snort: ET SCAN Suspicious inbound to PostgreSQL port 5432	8	100002	192.168.1.15	192.168.1.50	5432	T1046
May 13, 2026 @ 05:40:31.8...	debian-wazuh	pfSense Snort: ET SCAN Suspicious inbound to PostgreSQL port 5432	8	100002	192.168.1.15	192.168.1.50	5432	T1046
May 13, 2026 @ 05:40:20.5...	debian-wazuh	pfSense Snort: ET SCAN Suspicious inbound to Oracle SQL port 1521	8	100002	192.168.1.15	192.168.1.50	1521	T1046
May 13, 2026 @ 05:40:20.5...	debian-wazuh	pfSense Snort: ET SCAN Suspicious inbound to Oracle SQL port 1521	8	100002	192.168.1.15	192.168.1.50	1521	T1046
May 13, 2026 @ 05:39:54.7...	debian-wazuh	-	4	11	-	-	-	
May 13, 2026 @ 05:39:52.7...	debian-wazuh	Syslogd restarted.	5	1005	-	-	-	
May 13, 2026 @ 05:39:52.7...	debian-wazuh	pfSense Snort: ET SCAN Potential VNC Scan 5800-5820	8	100002	192.168.1.15	192.168.1.50	5807	T1046
May 13, 2026 @ 05:39:42.4...	debian-wazuh	pfSense Snort:	8	100002	-	-	-	T1046
May 13, 2026 @ 05:39:42.4...	debian-wazuh	pfSense Snort: ET SCAN Suspicious inbound to mySQL port 3306	8	100002	192.168.1.15	192.168.1.50	3306	T1046
May 13, 2026 @ 05:39:42.4...	debian-wazuh	pfSense Snort: ET SCAN Suspicious inbound to mySQL port 3306	8	100002	192.168.1.15	192.168.1.50	3306	T1046

Hình 3.3: Snort phát hiện hành vi scan port database, VNC, OS Detection

May 13, 2026 @ 05:41:24.7...	debian-wazuh	pfsense Snort: ET SCAN Nmap Scripting Engine User-Agent Detected (Nmap Scripting Engine)	8	100002	192.168.1.15	192.168.1.50	80	T1046
May 13, 2026 @ 05:41:24.6...	nginx-prod-01	Multiple web server 400 error codes from same source ip.	10	31151	192.168.1.15	-	-	T1595.002
May 13, 2026 @ 05:41:24.6...	nginx-prod-01	Web server 400 error code.	5	31101	192.168.1.15	-	-	
May 13, 2026 @ 05:41:24.6...	nginx-prod-01	Web server 400 error code.	5	31101	192.168.1.15	-	-	
May 13, 2026 @ 05:41:24.6...	nginx-prod-01	Web server 400 error code.	5	31101	192.168.1.15	-	-	
May 13, 2026 @ 05:41:24.6...	nginx-prod-01	Web server 400 error code.	5	31101	192.168.1.15	-	-	
May 13, 2026 @ 05:41:24.6...	nginx-prod-01	Web server 400 error code.	5	31101	192.168.1.15	-	-	
May 13, 2026 @ 05:41:24.6...	nginx-prod-01	Web server 400 error code.	5	31101	192.168.1.15	-	-	
May 13, 2026 @ 05:41:24.5...	nginx-prod-01	Web server 400 error code.	5	31101	192.168.1.15	-	-	
May 13, 2026 @ 05:41:24.5...	nginx-prod-01	Web server 400 error code.	5	31101	192.168.1.15	-	-	
May 13, 2026 @ 05:41:24.5...	nginx-prod-01	Web server 400 error code.	5	31101	192.168.1.15	-	-	
May 13, 2026 @ 05:41:24.5...	nginx-prod-01	Web server 400 error code.	5	31101	192.168.1.15	-	-	
May 13, 2026 @ 05:41:24.5...	nginx-prod-01	Web server 400 error code.	5	31101	192.168.1.15	-	-	
May 13, 2026 @ 05:41:24.5...	nginx-prod-01	Web server 400 error code.	5	31101	192.168.1.15	-	-	
May 13, 2026 @ 05:41:24.5...	nginx-prod-01	Web server 400 error code.	5	31101	192.168.1.15	-	-	
May 13, 2026 @ 05:41:24.5...	nginx-prod-01	Web server 400 error code.	5	31101	192.168.1.15	-	-	
May 13, 2026 @ 05:41:23.7...	debian-wazuh	pfsense Snort: ET SCAN NMAP OS Detection Probe	8	100002	192.168.1.15	192.168.1.50	43104	T1046
May 13, 2026 @ 05:41:23.7...	debian-wazuh	pfsense Snort: ET SCAN NMAP OS Detection Probe	8	100002	192.168.1.15	192.168.1.50	43104	T1046

Hình 3.4: Wazuh phân tích log và tăng Rule level từ 5 lên 10

Đánh giá kết quả: Kịch bản cho thấy hệ thống hoạt động tốt ở mức cơ bản. Snort giám sát ở tầng mạng và nhận diện chính xác các công cụ tấn công, trong khi Wazuh Agent phân tích được các hành vi thăm dò và dựa và cảnh báo phù hợp

3.3 Kịch bản 2: Evasive stealth scan

3.3.1 Mục tiêu

Mục tiêu của kịch bản này là kiểm tra khả năng phát hiện của hệ thống giám sát trước các kỹ thuật dò quét có áp dụng cơ chế lẩn tránh, bao gồm phân mảnh gói tin và sử dụng địa chỉ IP giả để giảm khả năng bị nhận diện

- Máy tấn công (Attacker): Chạy Arch Linux, IP 192.168.1.15
- Mục tiêu (Target): Địa chỉ IP WAN của tường lửa pfSense (192.168.1.50)
- Công cụ sử dụng: Nmap

3.3.2 Tiến hành thực nghiệm

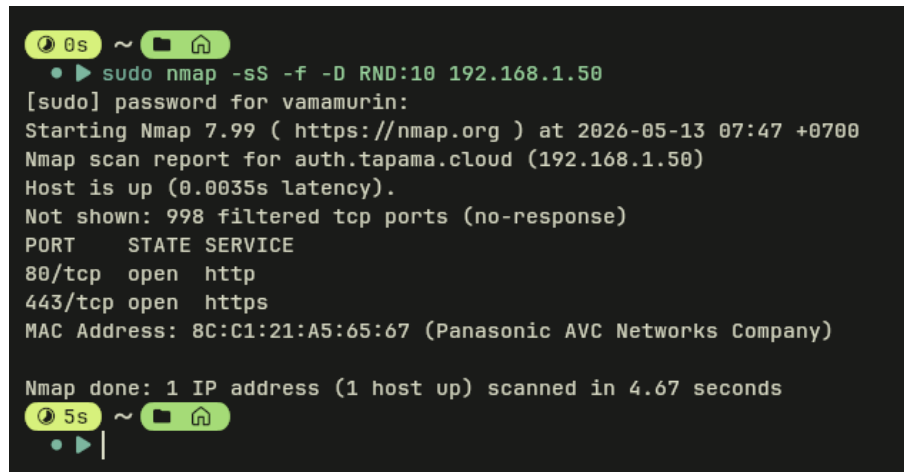
Từ máy tấn công, thực thi lệnh Nmap:

```
1 sudo nmap -sS -f -D RND:10 192.168.1.50
```

Trong đó:

- **-sS**: Thực hiện SYN Scan nhằm hạn chế hoàn tất kết nối TCP đầy đủ
- **-f**: Phân mảnh gói tin IP để thử vượt qua cơ chế kiểm tra của firewall/IDS
- **-D RND:10**: Sinh 10 địa chỉ IP giả (Decoy) nhằm gây nhiễu log và che giấu nguồn quét thực tế

Kỹ thuật này có ưu điểm là làm giảm khả năng nhận diện và gây khó khăn cho quá trình phân tích log. phù hợp để lựa chọn làm kịch bản thực nghiệm rà quét nâng cao



```
0s ~ 
• ▶ sudo nmap -sS -f -D RND:10 192.168.1.50
[sudo] password for vamamurin:
Starting Nmap 7.99 ( https://nmap.org ) at 2026-05-13 07:47 +0700
Nmap scan report for auth.tapama.cloud (192.168.1.50)
Host is up (0.0035s latency).
Not shown: 998 filtered tcp ports (no-response)
PORT      STATE SERVICE
80/tcp    open  http
443/tcp   open  https
MAC Address: 8C:C1:21:A5:65:67 (Panasonic AVC Networks Company)

Nmap done: 1 IP address (1 host up) scanned in 4.67 seconds
5s ~ 
• ▶ |
```

Hình 3.5: Evasive stealth scan từ máy tấn công

3.3.3 Kết quả thực nghiệm

Từ log thấy được rằng hệ thống giám sát đã phân tích thành công một phần kỹ thuật lẩn tránh, nhưng đồng thời cũng chịu tác động rõ rệt từ chiến thuật gây nhiễu:

- **Khả năng chống phân mảnh (De-fragmentation):** Snort trên pfSense hoạt động hiệu quả. Phân tích thành công các gói tin bị băm nhỏ bởi cờ `-f`, từ đó phát hiện chính xác hành vi rà quét nhắm vào các cổng cơ sở dữ liệu nhạy cảm (1433, 1521, 5432, 3306) và đẩy cảnh báo Mức độ 8 về Wazuh
- **Tác động của kỹ thuật giả mạo IP:** Tuy vậy chiến thuật chèn IP giả mạo `-D RND:10` đã phát huy tác dụng gây nhiễu. Snort ghi nhận hàng loạt cảnh báo quét cổng giống hệt nhau xuất phát từ 11 địa chỉ IP khác nhau (bao gồm 1 IP thật và 10 IP ngẫu nhiên) diễn ra trong cùng một lúc
- **Ghi nhận tại Wazuh SIEM:** Toàn bộ các cảnh báo này được đẩy về Dashboard, gây ra khó khăn trong việc phân tích và xử lý. Địa chỉ IP thật (192.168.1.15) bị chìm hoàn toàn giữa danh sách các IP giả mạo

May 13, 2026 @ 07:46:05.093	debian-wazuh	pfSense Snort: ET SCAN Suspicious inbound to Oracle SQL port 1521	8	100002	202.234.252.105	192.168.1.50	1521	T1046
May 13, 2026 @ 07:46:05.092	debian-wazuh	pfSense Snort: ET SCAN Suspicious inbound to Oracle SQL port 1521	8	100002	192.168.1.15	192.168.1.50	1521	T1046
May 13, 2026 @ 07:46:05.092	debian-wazuh	pfSense Snort: ET SCAN Suspicious inbound to Oracle SQL port 1521	8	100002	201.227.31.155	192.168.1.50	1521	T1046
May 13, 2026 @ 07:46:05.091	debian-wazuh	pfSense Snort: ET SCAN Suspicious inbound to Oracle SQL port 1521	8	100002	132.40.143.95	192.168.1.50	1521	T1046
May 13, 2026 @ 07:46:05.090	debian-wazuh	pfSense Snort: ET SCAN Suspicious inbound to Oracle SQL port 1521	8	100002	220.61.41.90	192.168.1.50	1521	T1046
May 13, 2026 @ 07:46:05.090	debian-wazuh	pfSense Snort: ET SCAN Suspicious inbound to Oracle SQL port 1521	8	100002	142.50.197.119	192.168.1.50	1521	T1046
May 13, 2026 @ 07:46:05.089	debian-wazuh	pfSense Snort: ET SCAN Suspicious inbound to Oracle SQL port 1521	8	100002	183.96.149.185	192.168.1.50	1521	T1046
May 13, 2026 @ 07:46:05.089	debian-wazuh	pfSense Snort: ET SCAN Suspicious inbound to Oracle SQL port 1521	8	100002	188.194.46.55	192.168.1.50	1521	T1046
May 13, 2026 @ 07:46:05.088	debian-wazuh	pfSense Snort: ET SCAN Suspicious inbound to PostgreSQL port 5432	8	100002	238.33.17.196	192.168.1.50	5432	T1046
May 13, 2026 @ 07:46:05.088	debian-wazuh	pfSense Snort: ET SCAN Suspicious inbound to Oracle SQL port 1521	8	100002	153.162.22.44	192.168.1.50	1521	T1046
May 13, 2026 @ 07:46:05.087	debian-wazuh	pfSense Snort: ET SCAN Suspicious inbound to PostgreSQL port 5432	8	100002	161.16.3.127	192.168.1.50	5432	T1046
May 13, 2026 @ 07:46:05.087	debian-wazuh	pfSense Snort: ET SCAN Suspicious inbound to PostgreSQL port 5432	8	100002	202.234.252.105	192.168.1.50	5432	T1046
May 13, 2026 @ 07:46:05.086	debian-wazuh	pfSense Snort: ET SCAN Suspicious inbound to PostgreSQL port 5432	8	100002	201.227.31.155	192.168.1.50	5432	T1046
May 13, 2026 @ 07:46:05.085	debian-wazuh	pfSense Snort: ET SCAN Suspicious inbound to PostgreSQL port 5432	8	100002	192.168.1.15	192.168.1.50	5432	T1046
May 13, 2026 @ 07:46:05.084	debian-wazuh	pfSense Snort: ET SCAN Suspicious inbound to PostgreSQL port 5432	8	100002	132.40.143.95	192.168.1.50	5432	T1046
May 13, 2026 @ 07:46:05.083	debian-wazuh	pfSense Snort: ET SCAN Suspicious inbound to PostgreSQL port 5432	8	100002	220.61.41.90	192.168.1.50	5432	T1046
May 13, 2026 @ 07:46:05.083	debian-wazuh	pfSense Snort: ET SCAN Suspicious inbound to PostgreSQL port 5432	8	100002	142.50.197.119	192.168.1.50	5432	T1046
May 13, 2026 @ 07:46:05.081	debian-wazuh	pfSense Snort: ET SCAN Suspicious inbound to PostgreSQL port 5432	8	100002	183.96.149.185	192.168.1.50	5432	T1046
May 13, 2026 @ 07:46:05.080	debian-wazuh	pfSense Snort: ET SCAN Suspicious inbound to PostgreSQL port 5432	8	100002	188.194.46.55	192.168.1.50	5432	T1046
May 13, 2026 @ 07:46:05.080	debian-wazuh	pfSense Snort: ET SCAN Suspicious inbound to PostgreSQL port 5432	8	100002	153.162.22.44	192.168.1.50	5432	T1046
May 13, 2026 @ 07:46:05.078	debian-wazuh	pfSense Snort: ET SCAN Suspicious inbound to Oracle SQL port 1521	8	100002	238.33.17.196	192.168.1.50	1521	T1046
May 13, 2026 @ 07:46:05.077	debian-wazuh	pfSense Snort: ET SCAN Suspicious inbound to Oracle SQL port 1521	8	100002	161.16.3.127	192.168.1.50	1521	T1046
May 13, 2026 @ 07:46:05.077	debian-wazuh	pfSense Snort: ET SCAN Suspicious inbound to Oracle SQL port 1521	8	100002	202.234.252.105	192.168.1.50	1521	T1046
May 13, 2026 @ 07:46:05.076	debian-wazuh	pfSense Snort: ET SCAN Suspicious inbound to Oracle SQL port 1521	8	100002	192.168.1.15	192.168.1.50	1521	T1046
May 13, 2026 @ 07:46:05.076	debian-wazuh	pfSense Snort: ET SCAN Suspicious inbound to Oracle SQL port 1521	8	100002	201.227.31.155	192.168.1.50	1521	T1046
May 13, 2026 @ 07:46:05.075	debian-wazuh	pfSense Snort: ET SCAN Suspicious inbound to Oracle SQL port 1521	8	100002	220.61.41.90	192.168.1.50	1521	T1046
May 13, 2026 @ 07:46:05.075	debian-wazuh	pfSense Snort: ET SCAN Suspicious inbound to Oracle SQL port 1521	8	100002	132.40.143.95	192.168.1.50	1521	T1046

Hình 3.6: Hiện tượng nhiễu loạn cảnh báo do kỹ thuật IP Spoofing tạo ra

3.3.4 Đánh giá kết quả

NIDS có khả năng chống lại kỹ thuật phân mảnh gói tin rất tốt. Tuy nhiên, kỹ thuật giả mạo IP đã thành công trong việc gây nhiễu thông tin. Điều này cho thấy hệ thống có thể phát hiện việc hạ tầng đang bị rà quét, nhưng việc lại gặp khó khăn truy vết chính xác IP gốc của kẻ tấn công. Để giải quyết vấn đề này, phải chờ kẻ tấn công thực hiện bước tiếp theo và sử dụng HIDS (Wazuh Agent) để nhằm đối chiếu thông tin

3.4 Kịch bản 3: Tấn công dò mật khẩu (Brute-force) và Phản ứng tự động

3.4.1 Mục tiêu

Mục tiêu của kịch bản này là đánh giá khả năng phân tích của SIEM Wazuh khi đối mặt với cuộc tấn công dò quét mật khẩu cường độ cao tại gateway (Identity-Aware Proxy), đồng thời kiểm tra tính năng tự động chặn kẻ tấn công

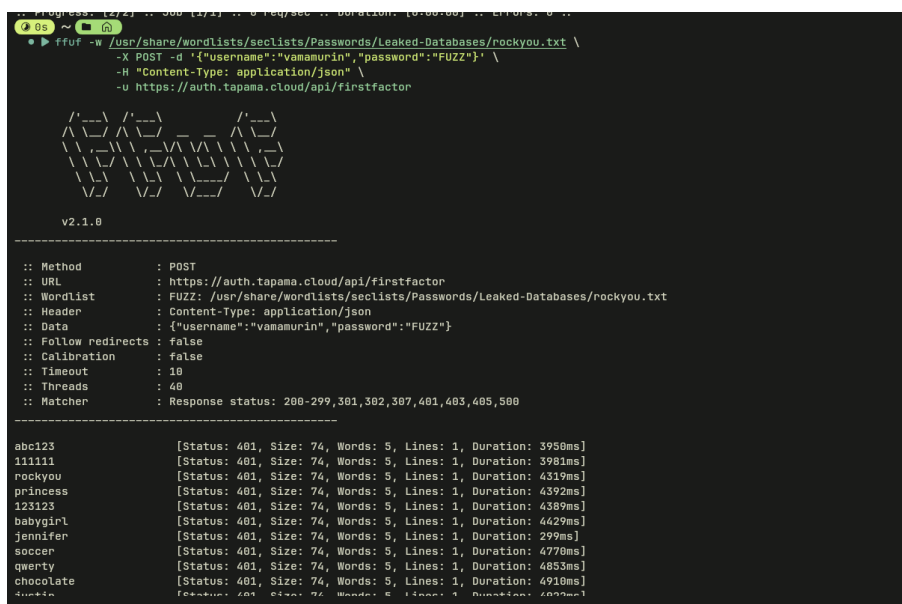
- Máy tấn công (Attacker): Chạy Arch Linux, IP 192.168.1.15
- Mục tiêu (Target): Cổng đăng nhập Web (`auth.tapama.cloud`) bảo vệ bởi Authelia tại VLAN 10
- Công cụ sử dụng: `ffuf` (Fuzz Faster U Fool) hoặc kịch bản Bash

3.4.2 Tiến hành thực nghiệm

Từ máy tấn công, sử dụng công cụ ffuf kết hợp với một danh sách mật khẩu phổ biến (Wordlist) để đẩy liên tục các truy vấn HTTP POST chứa thông tin đăng nhập sai vào API xác thực của Authelia:

```
1 ffuf -w /usr/share/wordlists/rockyou.txt \
2 -X POST -d '{"username":"admin","password":"FUZZ"}' \
3 -H "Content-Type: application/json" \
4 -u https://auth.tapama.cloud/api/firstfactor
```

Kỹ thuật này tạo ra hàng loạt yêu cầu xác thực thất bại trong thời gian cực ngắn nhằm kiểm tra sức chịu tải của Nginx và độ nhạy của Wazuh Agent trong việc đọc và bóc tách log hệ thống



```
ffuf -w /usr/share/wordlists/secLists/Passwords/Leaked-Databases/rockyou.txt \
-X POST -d '{"username":"viamurin","password":"FUZZ"}' \
-H "Content-Type: application/json" \
-u https://auth.tapama.cloud/api/firstfactor

v2.1.0

:: Method : POST
:: URL : https://auth.tapama.cloud/api/firstfactor
:: WordList : FUZZ: /usr/share/wordlists/secLists/Passwords/Leaked-Databases/rockyou.txt
:: Header : Content-Type: application/json
:: Data : {"username":"viamurin","password":"FUZZ"}
:: Follow redirects : false
:: Calibration : false
:: Timeout : 10
:: Threads : 40
:: Matcher : Response status: 200-299,301,302,307,401,403,405,500

abc123 [Status: 401, Size: 74, Words: 5, Lines: 1, Duration: 3950ms]
111111 [Status: 401, Size: 74, Words: 5, Lines: 1, Duration: 3981ms]
rockyou [Status: 401, Size: 74, Words: 5, Lines: 1, Duration: 4319ms]
princess [Status: 401, Size: 74, Words: 5, Lines: 1, Duration: 4392ms]
123123 [Status: 401, Size: 74, Words: 5, Lines: 1, Duration: 4389ms]
babygirl [Status: 401, Size: 74, Words: 5, Lines: 1, Duration: 4429ms]
jennifer [Status: 401, Size: 74, Words: 5, Lines: 1, Duration: 299ms]
soccer [Status: 401, Size: 74, Words: 5, Lines: 1, Duration: 4770ms]
qwerty [Status: 401, Size: 74, Words: 5, Lines: 1, Duration: 4853ms]
chocolate [Status: 401, Size: 74, Words: 5, Lines: 1, Duration: 4916ms]
```

Hình 3.7: Brute-force vào API xác thực của Authelia

3.4.3 Kết quả thực nghiệm

Hệ thống phân tích log tập trung đã xử lý được lượng lớn nhật ký sinh ra và ngay lập tức kích hoạt thành công tường lửa:

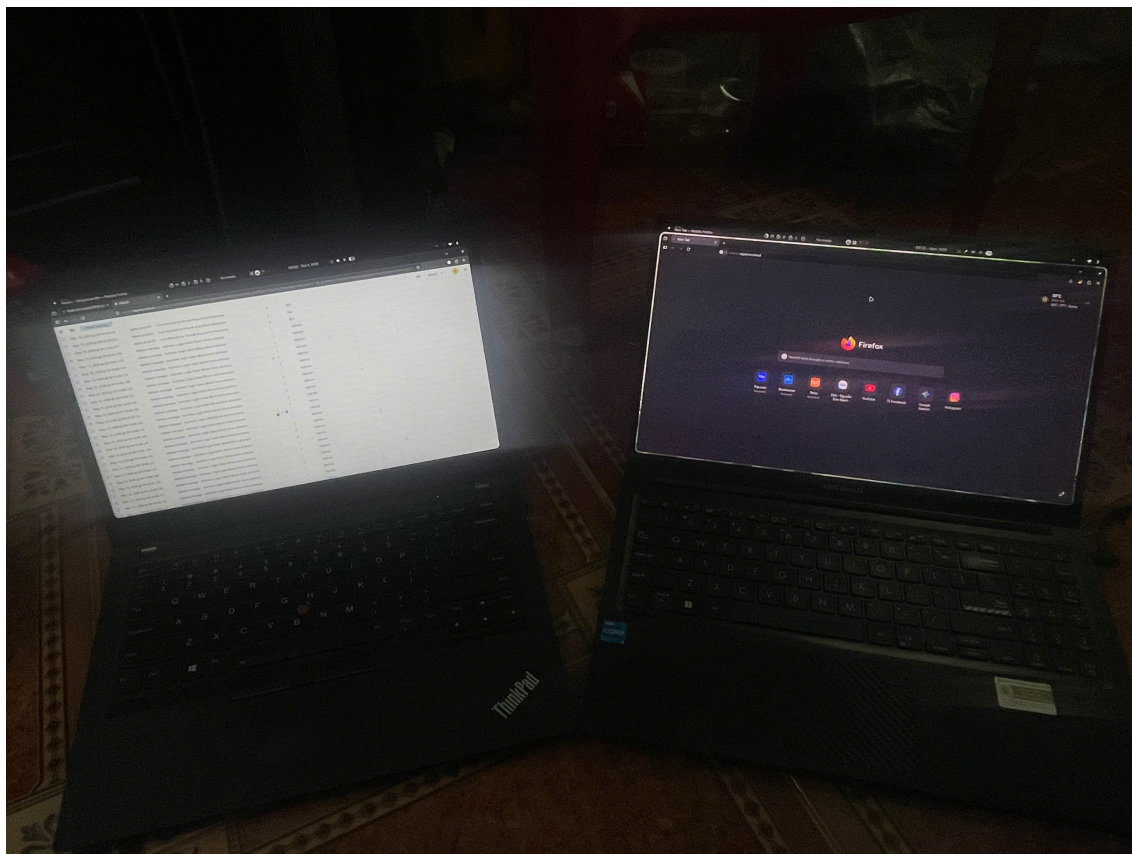
- **Detection và Correlation):** Hệ thống Authelia liên tục trả về mã lỗi 401 Unauthorized cho các truy vấn sai. Wazuh Agent cài trên Nginx tiến hành phân tích tệp `access.log` theo thời gian thực. SIEM đã gộp các lỗi đăng nhập rời rạc từ IP 192.168.1.15 thành một chuỗi sự kiện logic, kích hoạt cảnh báo *Multiple authentication failures* ở mức độ cực kỳ nghiêm trọng (Level 10)

- **Phản ứng tự động (Active Response):** Ngay khi Rule Level 10 bị kích hoạt, hệ thống tự động kích hoạt **firewall-drop**. Lệnh này được đẩy thẳng xuống cấu hình iptables của máy chủ phân giải, đưa IP của kẻ tấn công vào danh sách đen (Blacklist) và ngắt toàn bộ kết nối mạng của IP này trong 300 giây

timestamp	agent.name	rule.description	rule.level	rule.id	data.scrip	data.dstip	data.dstport	rule.mitre.id
May 13, 2026 @ 09:23:49.976	nginx-prod-01	Host Unblocked by firewall-drop Active Response	3	652	-	-	-	
May 13, 2026 @ 09:19:11.977	nginx-prod-01	Web server 400 error code.	5	31101	192.168.1.16	-	-	
May 13, 2026 @ 09:18:49.936	nginx-prod-01	Host Blocked by firewall-drop Active Response	3	651	-	-	-	
May 13, 2026 @ 09:18:49.925	nginx-prod-01	Host Blocked by firewall-drop Active Response	3	651	-	-	-	
May 13, 2026 @ 09:18:49.912	nginx-prod-01	Host Blocked by firewall-drop Active Response	3	651	-	-	-	
May 13, 2026 @ 09:18:48.176	debian-manager	Authelia: Login failed (Brute-force attempt)	7	100101	-	-	-	
May 13, 2026 @ 09:18:48.174	debian-manager	Authelia: Login failed (Brute-force attempt)	7	100101	-	-	-	
May 13, 2026 @ 09:18:48.174	debian-manager	Authelia: Login failed (Brute-force attempt)	7	100101	-	-	-	
May 13, 2026 @ 09:18:48.172	debian-manager	Authelia: Login failed (Brute-force attempt)	7	100101	-	-	-	
May 13, 2026 @ 09:18:48.166	debian-manager	Authelia: Login failed (Brute-force attempt)	7	100101	-	-	-	
May 13, 2026 @ 09:18:48.163	debian-manager	Authelia: Login failed (Brute-force attempt)	7	100101	-	-	-	
May 13, 2026 @ 09:18:48.161	debian-manager	Authelia: Login failed (Brute-force attempt)	7	100101	-	-	-	
May 13, 2026 @ 09:18:48.159	debian-manager	Authelia: Login failed (Brute-force attempt)	7	100101	-	-	-	
May 13, 2026 @ 09:18:48.158	debian-manager	Authelia: Login failed (Brute-force attempt)	7	100101	-	-	-	
May 13, 2026 @ 09:18:48.157	debian-manager	Authelia: Login failed (Brute-force attempt)	7	100101	-	-	-	
May 13, 2026 @ 09:18:48.149	debian-manager	Authelia: Login failed (Brute-force attempt)	7	100101	-	-	-	
May 13, 2026 @ 09:18:48.146	debian-manager	Authelia: Login failed (Brute-force attempt)	7	100101	-	-	-	
May 13, 2026 @ 09:18:48.144	debian-manager	Authelia: Login failed (Brute-force attempt)	7	100101	-	-	-	
May 13, 2026 @ 09:18:48.142	debian-manager	Authelia: Login failed (Brute-force attempt)	7	100101	-	-	-	
May 13, 2026 @ 09:18:48.138	debian-manager	Authelia: Login failed (Brute-force attempt)	7	100101	-	-	-	
May 13, 2026 @ 09:18:48.136	debian-manager	Authelia: Login failed (Brute-force attempt)	7	100101	-	-	-	
May 13, 2026 @ 09:18:48.131	debian-manager	Authelia: Login failed (Brute-force attempt)	7	100101	-	-	-	
May 13, 2026 @ 09:18:48.131	debian-manager	Authelia: Login failed (Brute-force attempt)	7	100101	-	-	-	
May 13, 2026 @ 09:18:48.130	debian-manager	Authelia: Login failed (Brute-force attempt)	7	100101	-	-	-	
May 13, 2026 @ 09:18:48.129	debian-manager	Authelia: Login failed (Brute-force attempt)	7	100101	-	-	-	

Hình 3.8: Wazuh xử lý cảnh báo Brute-force và tự động kích hoạt chặn IP

Hình 3.9 cho thấy thiết bị của kẻ tấn công không thể truy cập vào hệ thống trong khi thiết bị khác vẫn truy cập bình thường



Hình 3.9: Wazuh block thiết bị kẻ tấn công

3.4.4 Đánh giá kết quả

Hệ thống đã thành công phòng thủ chủ động. Việc tự động hóa quy trình phản ứng sự cố giúp cắt đứt chuỗi tấn công, bảo vệ an toàn cho hệ thống. Cơ chế này giúp giảm thiểu việc quá tải cảnh báo, giúp quản trị viên SOC không phải thao tác cấu hình tường lửa thủ công cho từng cuộc tấn công

3.5 Kịch bản 4: Giám sát toàn vẹn tệp tin (FIM) tại điểm cuối

3.5.1 Mục tiêu

Mục tiêu của kịch bản này là kiểm tra năng lực giám sát bảo mật điểm cuối thông qua module File Integrity Monitoring (FIM). Đánh giá khả năng phát hiện theo thời gian thực đối với các hành vi tạo mới hoặc sửa đổi tệp tin trái phép trong thư mục lõi của ứng dụng Web

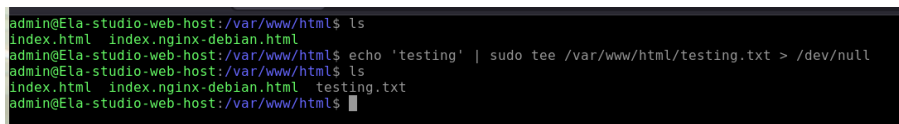
- Máy tấn công (Attacker): Chạy Arch Linux, mô phỏng hành vi đã vượt qua lớp mạng và có quyền tải tệp lên Web
- Mục tiêu (Target): Thư mục chứa mã nguồn Web (`/var/www/html`) trên máy ảo của Khách thuê (Tenant VM)
- Công cụ sử dụng: Tệp tin chứa chữ ký mã độc chuẩn EICAR nhằm giả lập một tệp Web Shell

3.5.2 Tiến hành thực nghiệm

Tại máy ảo Tenant, tiến hành mô phỏng hành vi thả mã độc vào máy của kẻ tấn công bằng cách tạo một tệp tin bất kỳ vào thư mục Web đang được giám sát bởi Wazuh Agent:

```
1 echo 'testing' | sudo tee /var/www/html/eicar.txt > /dev/null
```

Khi tệp tin được ghi xuống đĩa cứng, hệ thống FIM sẽ ngay lập tức kích hoạt cơ chế quét mã băm (Hash MD5, SHA1, SHA256) và gửi về máy chủ SOC để đối chiếu với tập luật



```
admin@Ela-studio-web-host:/var/www/html$ ls
index.html index.nginx-debian.html
admin@Ela-studio-web-host:/var/www/html$ echo 'testing' | sudo tee /var/www/html/testing.txt > /dev/null
admin@Ela-studio-web-host:/var/www/html$ ls
index.html index.nginx-debian.html testing.txt
admin@Ela-studio-web-host:/var/www/html$
```

Hình 3.10: Thực thi hành vi thả tệp tin giả lập mã độc EICAR vào máy chủ Web

3.5.3 Kết quả thực nghiệm

- **Phát hiện được sự thay đổi của thư mục** Module FIM của Wazuh Agent bắt được sự kiện *File added to the system* tại đường dẫn `/var/www/html/test.txt`
- **Cảnh báo:** Sau đó Wazuh Server hiện lên trên dashboard để quản trị viên phát hiện

May 13, 2026 @ 10:38:47.629	Ela-studio-web-host	PAM: Login session closed.	3	5502	-
May 13, 2026 @ 10:38:47.628	Ela-studio-web-host	PAM: Login session opened.	3	5501	-
May 13, 2026 @ 10:38:47.627	Ela-studio-web-host	Successful sudo to ROOT executed.	3	5402	-
May 13, 2026 @ 10:38:46.251	Ela-studio-web-host	File added to the system.	5	554	-
May 13, 2026 @ 10:37:43.624	Ela-studio-web-host	PAM: Login session closed.	3	5502	-
May 13, 2026 @ 10:37:43.623	Ela-studio-web-host	PAM: Login session opened.	3	5501	-

Hình 3.11: Wazuh ghi nhận sự kiện FIM và phát cảnh báo tệp tin EICAR

3.5.4 Đánh giá kết quả

Kịch bản cho thấy hệ thống có thể phát hiện được sự thay đổi đối với cả những điểm cuối, từ đó có thể phân tích và đưa ra cảnh báo để quản trị viên có thể xử lý kịp thời.

3.6 Kết luận chương 3

Các kịch bản thực nghiệm trong chương này cho thấy hệ thống SOC được xây dựng đã có khả năng giám sát và phát hiện nhiều nhóm hành vi tấn công phổ biến trong môi trường thực tế, từ rà quét dịch vụ, kỹ thuật lẩn tránh, dò mật khẩu cho đến thay đổi trái phép trên điểm cuối.

Ở tầng mạng, NIDS Snort có thể nhận diện tương đối hiệu quả các hoạt động thăm dò và các mẫu lưu lượng bất thường, kể cả khi đối tượng sử dụng kỹ thuật phân mảnh gói tin. Trong khi đó, Wazuh SIEM và HIDS thể hiện vai trò quan trọng trong việc phân tích tương quan log, tổng hợp sự kiện và hỗ trợ phản ứng tự động khi xảy ra tấn công brute-force hoặc thay đổi tệp tin bất thường trên máy chủ.

Tuy nhiên, quá trình thực nghiệm cũng cho thấy một số hạn chế mang tính thực tế. Các kỹ thuật gây nhiễu như Decoy Scan vẫn tạo ra lượng lớn cảnh báo và làm khó khăn hơn cho quá trình truy vết nguồn tấn công. Trong nhiều trường hợp, SOC chỉ có thể nhận biết rằng hệ thống đang bị thăm dò hoặc khai thác, còn việc điều tra sâu hơn vẫn cần sự phối hợp giữa nhiều lớp giám sát và quá trình phân tích thủ công của quản trị viên.

Bên cạnh đó, các cơ chế phản ứng tự động tuy mang lại hiệu quả rõ rệt trong việc giảm thời gian xử lý sự cố, nhưng nếu cấu hình chưa phù hợp vẫn có nguy cơ gây chặn nhầm hoặc tạo thêm nhiễu cảnh báo trong hệ thống.

Nhìn chung, kết quả thực nghiệm cho thấy mô hình SOC được triển khai đã đáp ứng tốt các yêu cầu giám sát và cảnh báo. Đồng thời, các thử nghiệm cũng phản ánh rằng bài toán giám sát an ninh mạng trong thực tế không chỉ dừng ở việc phát hiện tấn công, mà còn nằm ở khả năng phân tích, tương quan và xử lý khối lượng lớn sự kiện phát sinh liên tục trong hệ thống.

Kết luận

Tổng kết kết quả đạt được

Đồ án đã hoàn thiện việc xây dựng và vận hành thử nghiệm một mô hình hạ tầng cho Trung tâm điều hành an toàn thông tin (SOC) ở quy mô nhỏ dựa trên các giải pháp mã nguồn mở. Hệ thống tập trung vào các chức năng giám sát tập trung, phân tích sự kiện bảo mật và hỗ trợ cảnh báo theo thời gian thực.

Các thành phần chính của hệ thống bao gồm pfSense đảm nhiệm vai trò tường lửa và gateway mạng, Snort thực hiện giám sát xâm nhập ở tầng mạng (NIDS), Authelia cung cấp cơ chế xác thực tập trung, trong khi Wazuh đóng vai trò SIEM kết hợp HIDS để thu thập và phân tích log.

Trong quá trình thực nghiệm, đồ án đã triển khai thành công mô hình phòng thủ nhiều lớp, kết hợp giữa giám sát tại biên mạng và giám sát trên thiết bị đầu cuối. Hệ thống được kiểm tra thông qua nhiều kịch bản mô phỏng hành vi tấn công thực tế như dò quét cổng dịch vụ, kỹ thuật lẩn tránh bằng phân mảnh gói tin và IP giả mạo, tấn công dò mật khẩu và giám sát thay đổi tệp tin trên máy chủ.

Đánh giá hiệu quả hệ thống

Kết quả thực nghiệm cho thấy hệ thống đáp ứng tương đối tốt các yêu cầu giám sát cơ bản trong môi trường mạng nội bộ.

- **Khả năng tập trung và quản lý log:** Wazuh SIEM có thể thu thập và đồng bộ log từ nhiều nguồn khác nhau như tường lửa, máy chủ Web, hệ điều hành và cổng xác thực về cùng một Dashboard, hỗ trợ quá trình giám sát tập trung.
- **Phân tích tương quan sự kiện:** Hệ thống có khả năng nhận diện các hành vi bất thường thông qua việc tổng hợp nhiều log riêng lẻ thành một chuỗi sự kiện có liên quan, từ đó giảm bớt khối lượng log thô cần xử lý thủ công.
- **Giám sát điểm cuối:** Module FIM của Wazuh theo dõi được các thay đổi xảy ra trên hệ thống tệp tin, bao gồm việc tạo mới hoặc chỉnh sửa dữ liệu trong các thư mục quan trọng của ứng dụng Web.

- **Khả năng phối hợp giữa các lớp bảo vệ:** Các thành phần trong hệ thống hoạt động tương đối đồng bộ. Trong quá trình thực nghiệm brute-force, Authelia có thể thực hiện khóa xác thực ở tầng ứng dụng trong khi Wazuh tiếp tục ghi nhận và phân tích log phục vụ điều tra.

Những hạn chế của mô hình

Bên cạnh các kết quả đạt được, mô hình triển khai vẫn còn tồn tại một số hạn chế cả về mặt kỹ thuật lẫn vận hành.

- **Khả năng xử lý nhiễu cảnh báo:** Các kỹ thuật lẫn tránh như Decoy Scan tạo ra số lượng lớn cảnh báo từ nhiều địa chỉ IP khác nhau, khiến quá trình xác định nguồn tấn công thực sự trở nên khó khăn hơn đối với hệ thống IDS dựa trên chữ ký.
- **Rủi ro của cơ chế phản ứng tự động:** Việc triển khai Active Response giúp rút ngắn thời gian phản ứng trước sự cố, tuy nhiên vẫn tồn tại nguy cơ chặn nhầm các kết nối hợp lệ nếu hệ thống luật chưa được tinh chỉnh phù hợp.
- **Giới hạn trong phân tích lưu lượng mã hóa:** Do chưa triển khai cơ chế SSL/TLS Inspection, hệ thống NIDS hiện tại chưa thể phân tích sâu nội dung của các kết nối HTTPS, làm giảm khả năng quan sát đối với lưu lượng mã hóa.
- **Giới hạn tài nguyên hệ thống:** Mô hình SIEM yêu cầu tương đối nhiều tài nguyên lưu trữ và xử lý để duy trì việc indexing log theo thời gian thực. Với kiến trúc triển khai một nút (Single-node), hệ thống có thể gặp tình trạng quá tải nếu lưu lượng và số lượng log tăng cao trong môi trường thực tế.

Hướng phát triển

Từ quá trình triển khai và thực nghiệm, có thể thấy mô hình SOC hiện tại đã đáp ứng được các yêu cầu giám sát cơ bản trong môi trường mạng nội bộ. Tuy nhiên, để tiến gần hơn tới khả năng vận hành trong môi trường thực tế với quy mô lớn, tính thương mại và lưu lượng phức tạp, hệ thống vẫn cần tiếp tục được mở rộng và hoàn thiện ở các khía cạnh sau:

- **Nâng cấp hạ tầng ảo hóa với tính sẵn sàng cao (High Availability):** Mô hình hiện tại đang vận hành nền tảng Proxmox ở dạng máy chủ đơn lẻ (Single-node). Định hướng tiếp theo là xây dựng kiến trúc Proxmox Cluster kết hợp hệ thống lưu trữ phân tán (như Ceph) nhằm cung cấp cơ chế dự phòng (Failover), đảm bảo dịch vụ của khách thuê không bị gián đoạn khi xảy ra sự cố phần cứng máy chủ vật lý
- **Cải thiện trải nghiệm quản trị cho khách thuê (Tenant):** Hệ thống hiện tại chủ yếu thao tác qua dòng lệnh, gây khó khăn cho người dùng không chuyên. Việc tích hợp các bảng điều khiển quản trị trực quan (Control Panel) như cPanel, DirectAdmin hoặc CyberPanel sẽ giúp khách thuê dễ dàng triển khai, quản lý cấu hình web, cơ sở dữ liệu và chứng chỉ bảo mật một cách độc lập
- **Cung cấp cơ chế kết nối quản trị an toàn (SSH over HTTPS):** Nhằm tăng tính tiện dụng nhưng vẫn duy trì ranh giới bảo mật, hệ thống có thể triển khai giải pháp truy cập dòng lệnh thông qua giao thức web (Web-based SSH như Apache Guacamole) hoặc bọc luồng dữ liệu SSH bên trong đường hầm HTTPS (TLS Multiplexing). Phương pháp này giúp ẩn giấu cổng SSH tiêu chuẩn khỏi các đợt quét mạng, đồng thời tận dụng được lớp xác thực đa yếu tố và tường lửa web đang có sẵn
- **Bổ sung nguồn dữ liệu tình báo (Threat Intelligence) và giám sát điểm cuối:** Tích hợp các nền tảng chia sẻ dữ liệu (như MISP, VirusTotal) để đối chiếu chỉ dấu tấn công (IoC), đồng thời nâng cấp module FIM theo hướng EDR (Endpoint Detection and Response) kết hợp phân tích hành vi tiến trình nhằm phát hiện mã độc tinh vi hoặc tấn công không dùng tệp tin (Fileless Malware)

- **Triển khai cơ chế SSL/TLS Inspection:** Thực hiện giải mã lưu lượng HTTPS tại máy chủ thiết bị trung gian (Proxy/Firewall) để hệ thống NIDS có khả năng phân tích sâu nội dung gói tin (DPI - Deep Packet Inspection), qua đó nhận diện chính xác các hành vi khai thác lỗ hổng web ở tầng ứng dụng
- **Chuyển dịch sang các giải pháp tiêu chuẩn doanh nghiệp (Enterprise-grade):** Kiến trúc hiện tại sử dụng nhiều công cụ phổ biến trong cộng đồng mã nguồn mở và máy chủ cá nhân (Self-hosted). Trong giai đoạn mở rộng, cần đánh giá và thay thế bằng các giải pháp chuyên biệt cho doanh nghiệp (ví dụ: chuyển đổi quản lý định danh sang Keycloak, hoặc sử dụng tường lửa thế hệ mới NGFW) nhằm đáp ứng các tiêu chuẩn tuân thủ an toàn thông tin khắt khe hơn và hỗ trợ đa tiền tố (Multi-tenancy) ở quy mô lớn
- **Hoàn thiện cơ chế SOAR và phản ứng tự động:** Phát triển các kịch bản phản ứng có tính logic vòng lặp, thay thế cho các lệnh chặn/cô lập đơn lẻ. Cơ chế mới cần kết hợp lưu trữ bằng chứng phục vụ điều tra số và cung cấp quy trình phê duyệt (Approval Workflow) để quản trị viên kiểm duyệt trước khi hệ thống thực thi lệnh can thiệp sâu vào dịch vụ

Nhìn chung, các hướng phát triển trên không chỉ giúp củng cố năng lực bảo mật cốt lõi của trung tâm điều hành SOC, mà còn đảm bảo hệ thống có đủ độ ổn định, tính thân thiện và khả năng đáp ứng các tiêu chuẩn dịch vụ khắt khe khi cung cấp hạ tầng điện toán đám mây cho nhiều khách hàng cùng lúc

Tài liệu tham khảo

- [1] UK Information Commissioner’s Office (ICO). (2016). *TalkTalk cyber attack – how the ICO’s investigation unfolded*. Truy cập từ: <https://ico.org.uk/about-the-ico/media-centre/talktalk-cyber-attack-how-the-ico-investigation-unfolded/>
- [2] House Oversight and Government Reform Committee. (2016). *The OPM Data Breach: How the Government Jeopardized Our National Security for More than a Generation*. Truy cập từ: <https://krebsonsecurity.com/2016/09/congressional-report-slams-opm-on-data-breach/>
- [3] House of Representatives. (2018). *The Equifax Data Breach - Majority Staff Report*. Truy cập từ: <https://oversight.house.gov/wp-content/uploads/2018/12/Equifax-Report.pdf>
- [4] Rose, S., Borchert, O., Mitchell, S., & Connelly, S. (2020). *Zero Trust Architecture*. NIST Special Publication 800-207. Truy cập từ: <https://csrc.nist.gov/publications/detail/sp/800-207/final>
- [5] Wazuh, Inc. (2024). *Wazuh Documentation: Installation, Configuration, and User Manual*. Truy cập từ: <https://documentation.wazuh.com/>
- [6] Cisco. (2024). *Snort 3 User Manual and Rule Writers Guide*. Truy cập từ: <https://docs.snort.org/>
- [7] Netgate. (2024). *pfSense Documentation: Firewall and Routing*. Truy cập từ: <https://docs.netgate.com/pfsense/en/latest/>
- [8] Authelia. (2024). *Authelia Official Documentation: Multi-Factor Authentication and Single Sign-On*. Truy cập từ: <https://www.authelia.com/docs/>
- [9] NGINX, Inc. (2024). *NGINX Reverse Proxy and Load Balancer*. Truy cập từ: <https://docs.nginx.com/nginx/admin-guide/web-server/reverse-proxy/>
- [10] Apache Software Foundation. (2024). *Apache Guacamole Manual: Clientless Remote Desktop Gateway*. Truy cập từ: <https://guacamole.apache.org/doc/gug/>

- [11] Proxmox Server Solutions GmbH. (2024). *Proxmox VE Administration Guide*. Truy cập từ: <https://pve.proxmox.com/pve-docs/pve-admin-guide.html>
- [12] The MITRE Corporation. (2024). *MITRE ATT&CK® Framework*. Truy cập từ: <https://attack.mitre.org/>
- [13] Ward, B., & Beyer, C. (2014). *BeyondCorp: A New Approach to Enterprise Security*. Google Whitepaper. Truy cập từ: <https://research.google/pubs/beyondcorp-a-new-approach-to-enterprise-security/>
- [14] Beyer, C., et al. (2015). *BeyondCorp: Design to Deployment at Google*. Google Whitepaper. Truy cập từ: <https://research.google/pubs/beyondcorp-design-to-deployment-at-google/>
- [15] Barclay, M., et al. (2016). *BeyondCorp: The Access Proxy*. Google Whitepaper. Truy cập từ: <https://research.google/pubs/beyondcorp-the-access-proxy/>
- [16] Saltonstall, J., et al. (2017). *BeyondCorp: The User Experience*. Google Whitepaper. Truy cập từ: <https://research.google/pubs/beyondcorp-the-user-experience/>

Phụ lục A

Cấu hình rules firewall

Interface	Protocol	Source	Destination	Port	Action	Mô tả chi tiết
WAN	TCP	Any	10.0.10.12 (Nginx)	80, 443	NAT	Forward luồng Web từ Internet vào IAP Gateway
VLAN 10	TCP	10.0.10.12	Firewall (Pfsense)	443	Pass	Cho phép Nginx Proxy Pass vào pfSense WebGUI
	TCP	10.0.10.12	10.0.20.10 (Wazuh)	443	Pass	Cho phép Nginx Proxy Pass vào Wazuh Dashboard
	TCP	VLAN 10 net	10.0.20.10	1514, 1515	Pass	Đẩy log HIDS từ Agent về máy chủ SIEM
	Any	VLAN 10 net	!RFC1918 (Internet)	Any	Pass	Ra Internet để cập nhật hệ thống
VLAN 20	Any	VLAN 20 net	!RFC1918 (Internet)	Any	Pass	Ra Internet để cập nhật Rule/Threat Intel
VLAN 30	TCP	VLAN 30 net	VLAN 40 net	3306	Pass	Cấp quyền DMZ truy vấn Database
	TCP/UDP	VLAN 30 net	10.0.20.10	1514, 1515	Pass	Đẩy log HIDS từ Agent về máy chủ SIEM
	Any	VLAN 30 net	!RFC1918 (Internet)	Any	Pass	Truy cập Internet (Ngăn chặn lây lan ngang)
VLAN 40	TCP/UDP	VLAN 40 net	10.0.20.10	1514, 1515	Pass	Đẩy log HIDS từ Agent về máy chủ SIEM

Bảng A.1: Tổng hợp Firewall Rules trên pfSense

Phụ lục B

Bộ giải mã tùy chỉnh (Custom Decoder) cho pfSense trên Wazuh

XML Decoder cấu hình tại `/var/ossec/etc/decoders/local_decoder.xml` để giúp Wazuh Manager dùng biểu thức Regex tách chính xác các trường dữ liệu (IP, Port, Phân loại mã độc) từ log Syslog do pfSense đẩy về.

Listing B.1: Custom Wazuh Decoder bắt sự kiện Snort

```
1 <decoder name="pfsense-snort-custom">
2   <prematch type="pcre2">\[\d+:\d+:\d+\]</prematch>
3 </decoder>
4
5 <decoder name="pfsense-snort-fields">
6   <parent>pfsense-snort-custom</parent>
7   <regex type="pcre2">\[(\d+:\d+:\d+)\]\s+(.*?)\s+(?:\[
      Classification:\s+(.*?)\]\s+)?(?:\[Priority:\s+(\d+)
      \]\s+)?\{(\w+)\}\s+(\d+\.\d+\.\d+\.\d+)(?::(\d+))?\s
      +->\s+(\d+\.\d+\.\d+\.\d+)(?::(\d+))?</regex>
8   <order>snort_id, description, classification, priority,
      protocol, srcip, srcport, dstip, dstport</order>
9 </decoder>
```

Phụ lục C

Script Systemd Service cho Tomcat 9 trên Debian 12

Kịch bản (Script) cấu hình tệp dịch vụ `tomcat.service` để vận hành Tomcat 9 như một tiến trình ngầm độc lập (Standalone Service), giải quyết vấn đề Debian 12 khai tử gói Tomcat 9 trên kho lưu trữ mặc định.

Listing C.1: Cấu hình `/etc/systemd/system/tomcat.service`

```
1 [Unit]
2 Description=Apache Tomcat 9 Web Application Container
3 After=network.target
4
5 [Service]
6 Type=forking
7 User=tomcat
8 Group=tomcat
9
10 Environment="JAVA_HOME=/usr/lib/jvm/default-java"
11 Environment="CATALINA_PID=/opt/tomcat/temp/tomcat.pid"
12 Environment="CATALINA_HOME=/opt/tomcat"
13 Environment="CATALINA_BASE=/opt/tomcat"
14 Environment="CATALINA_OPTS=-Xms512M-Xmx1024M-server-XX:+
    UseParallelGC"
15 Environment="JAVA_OPTS=-Djava.awt.headless=true"
16 Environment="GUACAMOLE_HOME=/etc/guacamole"
17
18 ExecStart=/opt/tomcat/bin/startup.sh
19 ExecStop=/opt/tomcat/bin/shutdown.sh
20
21 [Install]
22 WantedBy=multi-user.target
```